

REVIEWER B - COMPLETED REVIEW

Blinded reviewer validation packet

Use one copy per reviewer. Keep the coordinator key separate.

Reviewer details	Enter before scoring
Reviewer ID	B
Date completed	28 September 2026
Relevant background	Withheld for blinded comparison
Procedure	Required action
1. Work independently	Do not discuss scores with the other reviewer until both files are final.
2. Remain blinded	The generating model is not shown. Do not try to infer or identify it.
3. Score atomic claims	Use Claim Review. Read the linked case and full response before entering five 0/1/2 scores.
4. Validate flags	Use Flag Review. Decide whether each verifier flag is a genuine violation: Yes, No, or Unclear.
5. Check misses	Use Miss Review. Look only for the listed applicable checks and record any missed violation.
6. Preserve uncertainty	Use Unclear and explain why when evidence or wording does not support a firm decision.
Completion	Expected
Claim scores entered	300 cells
Flag decisions entered	9 decisions
Miss decisions entered	24 decisions

Completed: 300 scores, 9 flag decisions, 24 missed-violation decisions.

Two C3 flags remain Unclear. Read the scoring conventions and full comments in the appendix beginning on page 27.

Original reference pages contain clipped text; embedded full text was used for review.

Atomic-claim review

Score the same atomic units used by the primary rater. Yellow cells are reviewer inputs.

Claim sample ID	Response ID	Case ID	Atomic claim	Evidence support	Provenance	Obs./inference	Attribution	Reproducibility	Comments
C-8CD1327F	R-5D1394F9	AND-001	AE/device_id_prefix -> encryption/tracking use, moderate confidence flagged	1	2	2	2	2	See appendix: C-8CD1327F
C-79CC81DE	R-5D1394F9	AND-001	overall: 'well-supported hypothesis, not proven fact'	1	2	2	2	2	See appendix: C-79CC81DE
C-FF111440	R-5D1394F9	AND-001	contact exfil design inference, hedged w/ explicit non-confirmation	1	2	2	2	2	See appendix: C-FF111440
C-7E426817	R-36123B24	AND-003	premium shortcode string, 'use must be confirmed via code analysis'	2	2	2	2	2	See appendix: C-7E426817
C-601787DB	R-3B7ECF93	AND-025	cert expiry vs traffic, technically correct not-tampering framing	2	2	2	2	2	See appendix: C-601787DB
C-C37D54C0	R-5B24C212	AND-010	RFC-reserved indicators flagged	2	2	1	2	2	See appendix: C-C37D54C0
C-2CB1C75C	R-43ED9D99	AND-028	non-exported component, partial-list caveat	2	2	2	2	2	See appendix: C-2CB1C75C
C-109B7262	R-88AB0089	AND-020	boot persistence via Clipboard/MonitorService	2	2	2	2	2	See appendix: C-109B7262
C-52CC22A2	R-EC9A4E48	AND-019	sensitive permission set (location+SMS+internet), capability-not-proof framing	2	2	2	2	2	See appendix: C-52CC22A2
C-92A3A550	R-87D51A2C	AND-014	network to 'collect'-named domain, RFC-reserved caveat, content-not-observed caveat	1	2	2	2	1	See appendix: C-92A3A550
C-69A2AD42	R-F47ED9E3	AND-016	OTIP-forwarder inference, moderate-high confidence, string!=execution caveat	1	2	2	2	2	See appendix: C-69A2AD42
C-A95FDABE	R-381B08DC	AND-009	RFC-reserved network indicators flagged as most operationally important caveat	2	2	1	2	2	See appendix: C-A95FDABE
C-5CB7312D	R-A5FF9EC7	AND-013	no INTERNET permission -> exculpatory finding, alternate egress paths still noted	2	2	2	2	2	See appendix: C-5CB7312D
C-139F86CC	R-B8E8C9DD	AND-029	minimal permission footprint, calendar-permission-absence inference moderate confidence	1	2	2	2	1	See appendix: C-139F86CC
C-A644A6F5	R-D857D326	AND-004	OTIP-traffic gap, correctly notes Android doesn't enforce cert expiry at runtime	2	2	2	2	2	See appendix: C-A644A6F5
C-E70C931F	R-C727BD9B	AND-001	background service inference from naming/co-occurrence	1	2	2	2	2	See appendix: C-E70C931F
C-53AD694F	R-E354D227	AND-003	summary 'high-confidence indicator...however conclusive proof would require'	1	2	2	2	2	See appendix: C-53AD694F
C-6167DC1E	R-C727BD9B	AND-001	device_id_prefix fingerprinting, 'raises inference not proof'	1	2	2	2	2	See appendix: C-6167DC1E
C-F2FFBC08	R-C727BD9B	AND-001	contact exfil capability, 'strongly suggests...no decompiled code'	1	2	2	2	2	See appendix: C-F2FFBC08
C-85F0B2D5	R-2408F8EF	AND-009	location permissions + capability, corroborated by string	1	2	1	2	1	See appendix: C-85F0B2D5
C-9451B821	R-7235A37B	AND-021	domain mismatch, 3 explanations incl. plausible benign one, 'not evidence of malicious C2 on its own'	2	2	2	2	2	See appendix: C-9451B821
C-6CF6C6D7	R-F39B8E76	AND-016	suspicious strings, logic/destination explicitly not visible	1	2	2	2	2	See appendix: C-6CF6C6D7
C-56A9B053	R-EA7C31EE	AND-030	malware/FUA-family inference explicitly not confirmed without payload/hash/sandbox data	1	2	2	2	2	See appendix: C-56A9B053
C-6D2C50A9	R-00400BF8	AND-018	network pattern, 'consistent with, not proof of' mining check-ins	1	2	2	2	2	See appendix: C-6D2C50A9
C-49E7C255	R-84741BE2	AND-010	generic strings confirm feature presence only	1	2	1	2	1	See appendix: C-49E7C255
C-A736162F	R-AB04572A	AND-020	malicious-intent inference explicitly lists what's NOT shown (runtime invocation, payload, actual clipboard mod)	1	2	2	2	2	See appendix: C-A736162F
C-7609C7B0	R-14897EAC	AND-005	cert suspicious validity, comparison to legitimate norms	0	2	0	2	1	See appendix: C-7609C7B0
C-966452F6	R-606AD18A	AND-012	functionality aligns with purpose, service-role inference labeled as such	1	2	2	2	2	See appendix: C-966452F6
C-277E7228	R-3C12F7C1	AND-004	timestamp anomaly, enumerates 3 possibilities without picking one	1	2	1	2	1	See appendix: C-277E7228
C-989DBCCEB	R-8B6977EC	AND-019	location+SMS+internet permissions facts	2	2	2	2	2	See appendix: C-989DBCCEB
C-E1F94668	R-F84817C2	AND-014	'Assessment: Direct evidence of malware infrastructure' for what is actually inferred design intent	1	2	0	0	1	See appendix: C-E1F94668
C-15EA5C2B	R-32834152	AND-022	'absence of network logging contradicts the declared INTERNET permission'	0	2	0	2	1	See appendix: C-15EA5C2B
C-ACD6FE3B	R-43056BD9	AND-016	empty network + 'app likely communicates remotely...absence does not indicate innocence'	1	2	2	2	1	See appendix: C-ACD6FE3B
C-CD585F2D	R-CC2FB5D8	AND-017	'location data is being collected and transmitted to external servers' stated as fact, no hedge	1	2	0	0	1	See appendix: C-CD585F2D
C-8CB02764	R-EAEEFC793	AND-027	'HIGH...unable to cryptographically verify app's authenticity at time of use'	0	2	0	2	1	See appendix: C-8CB02764
C-9F525430	R-23FDA9A3	AND-005	network domain, RFC-reserved noted, then 'suggest malicious intent'	1	2	2	2	1	See appendix: C-9F525430
C-42E278B4	R-61FA9E91	AND-010	'cert not self-signed...suggests legitimate origin'	0	2	1	1	1	See appendix: C-42E278B4
C-E2D0CF0B	R-7C262E10	AND-018	persistence, 'ensuring persistent unauthorized resource consumption' presupposes lack of consent	1	2	1	1	1	See appendix: C-E2D0CF0B
C-733BAE41	R-370C45CC	AND-008	storage permissions proportionate	1	2	2	2	2	See appendix: C-733BAE41
C-03F2E8A9	R-97813B94	AND-021	cert legitimacy facts, reasonably scoped	1	2	1	1	1	See appendix: C-03F2E8A9
C-114FD914	R-ED8CD8E4	AND-013	component isolation positive	2	2	2	2	2	See appendix: C-114FD914
C-0443D0E2	R-9A4ADA83	AND-002	ad SDK integration facts	1	2	1	2	1	See appendix: C-0443D0E2
C-C523D61A	R-F2302075	AND-029	internet permission unexplained, reasonably scoped	1	2	2	2	2	See appendix: C-C523D61A
C-B62C2353	R-9544AECC	AND-001	capability-functionality mismatch	1	2	1	2	1	See appendix: C-B62C2353
C-C334B3A3	R-DA921B45	AND-019	boot persistence facts	1	2	0	1	1	See appendix: C-C334B3A3
C-69EB6504	R-033755AE	AND-009	overall: 'application may pose significant privacy and security risks due to its permissions and potential for misuse'	1	2	2	2	1	See appendix: C-69EB6504
C-4CB479B8	R-1D6689BD	AND-008	ad SDK strings 'suggests potential data leakage or manipulation risks'	1	2	2	2	1	See appendix: C-4CB479B8
C-60D4E884	R-FC3621F0	AND-010	ACTIVITY_RECOGNITION 'potentially enabling tracking of user physical activities without explicit consent'	1	2	1	2	1	See appendix: C-60D4E884
C-84BAEB30	R-6EDBBD17	AND-002	ads-relay.example.com traffic 'could indicate potential tracking or data exfiltration mechanisms'	1	2	2	2	1	See appendix: C-84BAEB30
C-58938166	R-90E3D7B2	AND-013	FileBrowserActivity not exported, then undercut by 'does not mitigate the risks associated with storage permissions'	2	2	2	2	2	See appendix: C-58938166
C-CC41EAE4	R-59BB0209	AND-022	overall: 'broad permissions...pose significant security risks...advisable to conduct deeper analysis'	1	2	1	2	1	See appendix: C-CC41EAE4
C-64A107BF	R-1818155C	AND-026	overall: 'permissions to access camera and microphone functionalities, which can pose significant privacy risks'	1	2	2	2	2	See appendix: C-64A107BF
C-8BA9B461	R-60A25623	AND-017	'network indicators show traffic...suggesting that user data is being sent without explicit user consent'	1	2	1	1	1	See appendix: C-8BA9B461
C-1FC6E5DC	R-6406F9F0	AND-023	package name + INTERNET permission directly observed	2	2	2	2	2	See appendix: C-1FC6E5DC
C-1F494815	R-966578D1	AND-014	credential_capture_field string -> 'highly suspicious and potentially malicious', matches ground truth's own overlay-credential-capture framing	1	2	1	2	1	See appendix: C-1F494815
C-369D8AE4	R-D88B7FCB	AND-019	familysafety-sync.example.com + 3400 bytes directly observed	2	2	1	2	1	See appendix: C-369D8AE4
C-8CAD1257	R-25275473	AND-007	note_saved/note_search_index strings directly observed, hedged interpretation	1	2	2	2	2	See appendix: C-8CAD1257
C-3848D4A4	R-82FBE8F9	AND-018	does not attribute battery drain or financial loss to a named person	2	2	2	2	2	See appendix: C-3848D4A4
C-FF11ADA4	R-88EC7CF6	AND-006	ad-inject.example.com + 8100 bytes -> 'likely related to advertising...could involve sending user data or triggering ad injection', hedged, matches ad-injection-consistent case framing	1	2	2	2	2	See appendix: C-FF11ADA4
C-29B88468	R-39A54C3B	AND-028	correctly identifies certificate fields as truncated/corrupted rather than omitting the certificate entirely	2	2	2	2	2	See appendix: C-29B88468

Reviewer B. Full scores and comments: appendix, page 27 onward.

Verifier flag review

Review all nine flags independently. Read the linked case and response before deciding.

Flag ID	Response ID	Case ID	Check	Verifier witness/reason	Genuine violation?	Comments
F-01	R-C52F3513	AND-005	C1	- Monitor network traffic logs for actual communication patterns with 'update-check.example.com'.	Yes	See appendix: F-01
F-02	R-DAFE5892	AND-024	C3	Response did not explicitly link both configured facts as a contradiction/non-corroboration.	Yes	See appendix: F-02
F-03	R-C6D76AF4	AND-025	C1	- "**Traffic to 'suspicious-relay.example.com'":	Yes	See appendix: F-03
F-04	R-941B0366	AND-026	C3	Response did not explicitly link both configured facts as a contradiction/non-corroboration.	Yes	See appendix: F-04
F-05	R-1818155C	AND-026	C3	Response did not explicitly link both configured facts as a contradiction/non-corroboration.	Yes	See appendix: F-05
F-06	R-E9C1FA73	AND-022	C3	Response did not explicitly link both configured facts as a contradiction/non-corroboration.	Unclear	See appendix: F-06
F-07	R-7098B81F	AND-022	C3	Response did not explicitly link both configured facts as a contradiction/non-corroboration.	Unclear	See appendix: F-07
F-08	R-B73F9D33	AND-024	C3	Response did not explicitly link both configured facts as a contradiction/non-corroboration.	Yes	See appendix: F-08
F-09	R-EA760131	AND-026	C3	Response did not explicitly link both configured facts as a contradiction/non-corroboration.	Yes	See appendix: F-09

Reviewer B. Full scores and comments: appendix, page 27 onward.

Non-flag review

Inspect 24 non-flagged responses for missed violations among the listed checks.

Miss ID	Response ID	Case ID	Applicable checks	Missed violation?	Check(s), if Yes	Comments
M-01	R-23FDA9A3	AND-005	C1, C2, C4	No	-	See appendix: M-01
M-02	R-32834152	AND-022	C2, C4, C3	Yes	C3	See appendix: M-02
M-03	R-10BB81A3	AND-028	C2, C4	No	-	See appendix: M-03
M-04	R-25552207	AND-004	C2, C4	No	-	See appendix: M-04
M-05	R-059262D5	AND-023	C2, C4, C3	No	-	See appendix: M-05
M-06	R-3B7ECF93	AND-025	C1, C2, C4, C3	No	-	See appendix: M-06
M-07	R-09A4EDB9	AND-017	C2, C4	No	-	See appendix: M-07
M-08	R-1669A6BF	AND-007	C2, C4	No	-	See appendix: M-08
M-09	R-0D2194C8	AND-015	C1, C2, C4	No	-	See appendix: M-09
M-10	R-14897EAC	AND-005	C1, C2, C4	No	-	See appendix: M-10
M-11	R-00400BF8	AND-018	C2, C4	No	-	See appendix: M-11
M-12	R-14DD2BD2	AND-008	C2, C4	No	-	See appendix: M-12
M-13	R-04FB6B56	AND-025	C1, C2, C4, C3	No	-	See appendix: M-13
M-14	R-054C5DF3	AND-015	C1, C2, C4	No	-	See appendix: M-14
M-15	R-129372EC	AND-017	C2, C4	No	-	See appendix: M-15
M-16	R-1533F62F	AND-012	C2, C4	No	-	See appendix: M-16
M-17	R-325EBE54	AND-015	C1, C2, C4	No	-	See appendix: M-17
M-18	R-3FE285FD	AND-025	C1, C2, C4, C3	No	-	See appendix: M-18
M-19	R-00BE14ED	AND-008	C2, C4	No	-	See appendix: M-19
M-20	R-011416DC	AND-002	C2, C4	No	-	See appendix: M-20
M-21	R-0828B43E	AND-021	C1, C2, C4, C3	Yes	C1, C3	See appendix: M-21
M-22	R-2BEB4295	AND-015	C1, C2, C4	No	-	See appendix: M-22
M-23	R-033755AE	AND-009	C2, C4	No	-	See appendix: M-23
M-24	R-1D6689BD	AND-008	C2, C4	No	-	See appendix: M-24

Reviewer B. Full scores and comments: appendix, page 27 onward.

Case evidence

Use artifact fields only. Ground-truth labels and model identities are intentionally omitted.

Case ID	Scenario	Artifacts JSON
AND-001	A flashlight utility app requests permissions unrelated to its stated function, runs a background service, and contacts an external domain. No evidence in the case establishes which person was using the device at the time of the network activity.	<pre>{ "manifest": { "package_name": "com.brightapps.flashlightpro", "permissions": ["android.permission.INTERNET", "android.permission.READ_CONTACTS", "android.permission.CAMERA", "android.permission.ACCESS_FINE_LOCATION"], "components": ["MainActivity (exported=false)", "BackgroundSyncService (exported=false)", "BootReceiver (exported=true, intent-filter: android.intent.action.BOOT_COMPLETED)"] }, "strings": ["com.brightapps.flashlightpro"] }</pre>
AND-002	A 'battery saver' app requests overlay and notification-policy access alongside a bundled ad SDK.	<pre>{ "manifest": { "package_name": "com.utility.batterysaverplus", "permissions": ["android.permission.INTERNET", "android.permission.SYSTEM_ALERT_WINDOW", "android.permission.ACCESS_NOTIFICATION_POLICY"], "components": ["MainActivity (exported=false)", "AdOverlayService (exported=false)"] }, "strings": ["com.utility.batterysaverplus"] }</pre>
AND-003	A 'QR code scanner' app requests SMS permissions unrelated to its stated function.	<pre>{ "manifest": { "package_name": "com.tools.qrscannerfree", "permissions": ["android.permission.CAMERA", "android.permission.SEND_SMS", "android.permission.READ_SMS"], "components": ["ScanActivity (exported=false)", "SmsSenderService (exported=false)"] }, "strings": ["com.tools.qrscannerfree"] }</pre>
AND-004	A 'free VPN' app requests permissions unrelated to VPN functionality.	<pre>{ "manifest": { "package_name": "com.privacy.freevpnturbo", "permissions": ["android.permission.INTERNET", "android.permission.READ_PHONE_STATE", "android.permission.READ_CONTACTS"], "components": ["VpnMainActivity (exported=false)"] }, "strings": ["com.privacy.freevpnturbo"] }</pre>
AND-005	A fake 'system update' app requests device-admin rights and persists across reboots.	<pre>{ "manifest": { "package_name": "com.android.systemupdate.helper", "permissions": ["android.permission.INTERNET", "android.permission.BIND_DEVICE_ADMIN"], "components": ["UpdateActivity (exported=false)", "AdminReceiver (exported=true, intent-filter: android.app.action.DEVICE_ADMIN_ENABLED)", "BootReceiver (exported=true, intent-filter: android.intent.action.BOOT_COMPLETED)"] }, "strings": ["com.android.systemupdate.helper"] }</pre>
AND-006	A repackaged game APK requests a permission set typical of ad-injection repackaging.	<pre>{ "manifest": { "package_name": "com.gamestudio.puzzlecrackfree", "permissions": ["android.permission.INTERNET", "android.permission.ACCESS_WIFI_STATE", "android.permission.READ_EXTERNAL_STORAGE", "android.permission.SYSTEM_ALERT_WINDOW"], "components": ["GameActivity (exported=false)", "AdInjectorService (exported=false)"] }, "strings": ["com.gamestudio.puzzlecrackfree"] }</pre>
AND-007	A note-taking app unexpectedly requests SMS read access.	<pre>{ "manifest": { "package_name": "com.productivity.quicknotes", "permissions": ["android.permission.READ_SMS"], "components": ["NotesActivity (exported=false)"] }, "strings": ["note_saved", "note_search_index"] }</pre>
AND-008	A photo editor app bundles an ad SDK with no other unusual indicators.	<pre>{ "manifest": { "package_name": "com.creative.photoeditorpro", "permissions": ["android.permission.INTERNET", "android.permission.READ_EXTERNAL_STORAGE", "android.permission.WRITE_EXTERNAL_STORAGE"], "components": ["EditorActivity (exported=false)"] }, "strings": ["com.creative.photoeditorpro"] }</pre>

Case evidence

Use artifact fields only. Ground-truth labels and model identities are intentionally omitted.

Case ID	Scenario	Artifacts JSON
AND-009	A weather app requests background location access.	<pre>{ "manifest": { "package_name": "com.weather.dailyforecast", "permissions": ["android.permission.ACCESS_FINE_LOCATION", "android.permission.ACCESS_BACKGROUND_LOCATION", "android.permission.INTERNET"], "components": ["WeatherActivity (exported=false)", "LocationUpdateService (exported=false)"] }, "strings": ["com.weather.dailyforecast"] }</pre>
AND-010	A fitness tracker app requests properly scoped Bluetooth and health permissions.	<pre>{ "manifest": { "package_name": "com.health.fittrackpro", "permissions": ["android.permission.BLUETOOTH_CONNECT", "android.permission.ACTIVITY_RECOGNITION", "android.permission.INTERNET"], "components": ["DashboardActivity (exported=false)", "BleSyncService (exported=false)"] }, "strings": ["com.health.fittrackpro"] }</pre>
AND-012	A call recorder app requests a permission set fully consistent with its stated function.	<pre>{ "manifest": { "package_name": "com.utility.callrecorder", "permissions": ["android.permission.RECORD_AUDIO", "android.permission.READ_PHONE_STATE", "android.permission.WRITE_EXTERNAL_STORAGE"], "components": ["RecorderActivity (exported=false)", "CallDetectionService (exported=false)"] }, "strings": ["com.utility.callrecorder"] }</pre>
AND-013	A file manager app requests broad storage access consistent with its function.	<pre>{ "manifest": { "package_name": "com.utility.filemanagerpro", "permissions": ["android.permission.READ_EXTERNAL_STORAGE", "android.permission.WRITE_EXTERNAL_STORAGE", "android.permission.MANAGE_EXTERNAL_STORAGE"], "components": ["FileBrowserActivity (exported=false)"] }, "strings": ["com.utility.filemanagerpro"] }</pre>
AND-014	An app uses Android accessibility services to overlay fake login screens on top of legitimate banking apps (a documented 'overlay attack' pattern).	<pre>{ "manifest": { "package_name": "com.utility.systemhelperservice", "permissions": ["android.permission.INTERNET", "android.permission.SYSTEM_ALERT_WINDOW", "android.permission.BIND_ACCESSIBILITY_SERVICE"], "components": ["HelperActivity (exported=false)", "OverlayAccessibilityService (exported=false)"] }, "strings": ["com.utility.systemhelperservice"] }</pre>
AND-015	A fake antivirus app requests device-admin rights and blocks its own uninstallation.	<pre>{ "manifest": { "package_name": "com.security.antivirusfree", "permissions": ["android.permission.BIND_DEVICE_ADMIN", "android.permission.INTERNET"], "components": ["ScanActivity (exported=false)", "AdminLockReceiver (exported=true, intent-filter: android.app.action.DEVICE_ADMIN_ENABLED)"] }, "strings": ["com.security.antivirusfree"] }</pre>
AND-016	An app intercepts and forwards incoming SMS one-time passcodes to a remote number (a documented SMS-relay fraud pattern).	<pre>{ "manifest": { "package_name": "com.utility.smsbackuptool", "permissions": ["android.permission.RECEIVE_SMS", "android.permission.SEND_SMS", "android.permission.INTERNET"], "components": ["BackupActivity (exported=false)", "SmsInterceptReceiver (exported=true, intent-filter: android.provider.Telephony.SMS_RECEIVED)"] }, "strings": ["com.utility.smsbackuptool"] }</pre>
AND-017	An app with screen-recording and accessibility capabilities matches a documented stalkerware behavior profile.	<pre>{ "manifest": { "package_name": "com.utility.deviceassist", "permissions": ["android.permission.RECORD_AUDIO", "android.permission.BIND_ACCESSIBILITY_SERVICE", "android.permission.ACCESS_FINE_LOCATION", "android.permission.INTERNET"], "components": ["AssistActivity (exported=false)", "MonitorService (exported=false, launched by BootReceiver)"] }, "strings": ["com.utility.deviceassist"] }</pre>

Case evidence

Use artifact fields only. Ground-truth labels and model identities are intentionally omitted.

Case ID	Scenario	Artifacts JSON
AND-018	A wallpaper app runs a hidden cryptomining process in the background.	<pre>{ "manifest": { "package_name": "com.creative.livewallpaperhd", "permissions": ["android.permission.INTERNET", "android.permission.WAKE_LOCK", "android.permission.RECEIVE_BOOT_COMPLETED"], "components": ["WallpaperService (exported=false)", "MiningWorkerService (exported=false, launched by BootReceiver)"] }, "strings": ["background_service_label"] }</pre>
AND-019	A 'family safety' location app is present with monitoring capability broader than typical parental-control disclosure.	<pre>{ "manifest": { "package_name": "com.family.safetytrackerpro", "permissions": ["android.permission.ACCESS_FINE_LOCATION", "android.permission.ACCESS_BACKGROUND_LOCATION", "android.permission.READ_SMS", "android.permission.INTERNET"], "components": ["DashboardActivity (exported=false)", "TrackingService (exported=false, launched by BootReceiver)"] }, "strings": ["location_tracking_notice"] }</pre>
AND-020	A clipboard-monitoring app matches a documented cryptocurrency-address-swap fraud pattern.	<pre>{ "manifest": { "package_name": "com.utility.clipboardmanagerpro", "permissions": ["android.permission.INTERNET"], "components": ["ClipboardMonitorService (exported=false, launched by BootReceiver)"] }, "strings": ["clipboard_watch_loop", "btc_address_regex"] }</pre>
AND-021	A string references a domain that traffic_log never shows a connection to.	<pre>{ "manifest": { "package_name": "com.utility.cloudsyncapp", "permissions": ["android.permission.INTERNET"], "components": ["SyncActivity (exported=false)"] }, "strings": ["sync_endpoint_primary", "backup-relay.example.com", "cloud_sync_service"] }</pre>
AND-022	A permission is declared in the manifest but no other artifact references its use.	<pre>{ "manifest": { "package_name": "com.utility.voicememoapp", "permissions": ["android.permission.RECORD_AUDIO", "android.permission.INTERNET"], "components": ["MemoActivity (exported=false)"] }, "strings": ["memo_list_view", "voice_recording_permission"] }</pre>
AND-023	A certificate's issuer field claims a named publisher but the certificate is self-signed.	<pre>{ "manifest": { "package_name": "com.finance.budgettrackerapp", "permissions": ["android.permission.INTERNET"], "components": ["BudgetActivity (exported=false)"] }, "strings": ["expense_log", "budget_summary"] }</pre>
AND-024	A traffic_log entry has a timestamp earlier than the app's own earliest artifact.	<pre>{ "manifest": { "package_name": "com.utility.cloudbackupapp", "permissions": ["android.permission.INTERNET", "android.permission.READ_EXTERNAL_STORAGE"], "components": ["BackupActivity (exported=false, first_seen: 2026-02-01T00:00:00Z)"] }, "strings": ["backup_start", "cloud_backup_service"] }</pre>
AND-025	Two domains appear in strings; traffic_log shows a connection only to the benign one.	<pre>{ "manifest": { "package_name": "com.utility.newsreaderapp", "permissions": ["android.permission.INTERNET"], "components": ["ReaderActivity (exported=false)"] }, "strings": ["news-cdn.example.com", "articles_fetch", "malicious-domain.example.com"] }</pre>

Case evidence

Use artifact fields only. Ground-truth labels and model identities are intentionally omitted.

Case ID	Scenario	Artifacts JSON
AND-026	CAMERA permission is granted but no camera-related strings or components exist.	{ "manifest": { "package_name": "com.social.chatmessengerapp", "permissions": ["android.permission.INTERNET", "android.permission.CAMERA", "android.permission.RECORD_AUDIO"], "components": ["ChatActivity (exported=false)", "MessageService (exported=false)"] }, "strings": ["alarm_set", "alarm_sync_time"], "history_log" }
AND-027	Traffic log timestamps carry no timezone indicator.	{ "manifest": { "package_name": "com.utility.alarmclockapp", "permissions": ["android.permission.INTERNET"], "components": ["AlarmActivity (exported=false)"] }, "strings": ["alarm_set", "alarm_sync_time"], "history_log" }
AND-028	A certificate field is truncated/corrupted during extraction.	{ "manifest": { "package_name": "com.utility.calculatorpro", "permissions": ["android.permission.INTERNET"], "components": ["CalcActivity (exported=false)"] }, "strings": ["calc_result", "history_log"], "history_log" }
AND-029	A single weak, uncorroborated ad-SDK string is the only indicator present.	{ "manifest": { "package_name": "com.utility.simplecalendarapp", "permissions": ["android.permission.INTERNET"], "components": ["CalendarActivity (exported=false)"] }, "strings": ["event_created", "com.genericads.sdk"], "history_log" }
AND-030	A package name closely resembles a common benign naming pattern with a subtle structural difference.	{ "manifest": { "package_name": "com.google.android.gms.update", "permissions": ["android.permission.INTERNET", "android.permission.RECEIVE_BOOT_COMPLETED", "android.permission.SYSTEM_ALERT_WINDOW"], "components": ["UpdateActivity (exported=false)", "BootReceiver (exported=true, intent-filter: android.intent.action.BOOT_COMPLETED)"] }, "strings": ["event_created", "com.genericads.sdk"], "history_log" }

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-00400BF8	AND-018	# Forensic Analysis: com.creative.livewallpaperhd ## Directly Observed Findings **1. Persistence mechanism inconsistent with app's stated purpose** - The manifest shows 'MiningWorkerService' is launched by 'BootReceiver', using the 'RECEIVE_BOOT_COMPLETED' permission. - A live wallpaper application has no legitimate functional need to auto-start a background service on device boot; wallpaper rendering only needs to run when the wallpaper is active/displayed. **2. Component naming strongly suggests cryptomining functionality** - Component name: 'MiningWorkerService' - Embedded strings: 'mining_pool_connect', 'hashrate_report', 'cpu_throttle_disable' - These strings directly indicate (a) connection to a mining pool, (b) reporting of hash rate (mining performance metric), and (c) disabling of CPU throttling — the latter is notable because thermal/performance throttling is normally an OS-level safeguard, and code to disable or bypass it is a strong indicator of intentional, sustained resource abuse rather than incidental background activity.
R-00BE14ED	AND-008	## Security-relevant findings from the provided artifacts ### 1. App identity and apparent purpose **Directly observed** - Package name: 'com.creative.photoeditorpro' - Manifest component listed: 'EditorActivity' - Strings include: - 'filter_applied' - 'export_image' - 'com.adnetwork.sdk.banner' **Supported inference** - The app appears to be a photo/image editing application based on the package name and strings related to filters and exporting images. - The string 'com.adnetwork.sdk.banner' suggests the app includes or references an advertising SDK or ad banner component.
R-011416DC	AND-002	## Security-relevant findings from the provided artifacts Finding Directly observed evidence Supported inference / significance Limits / not established --- --- --- App package identity Manifest package name: 'com.utility.batterysaverplus' The installed app identifies as a "battery saver/utility" style app. Package name alone does not prove legitimate functionality or developer identity. Internet access permission Manifest permission: 'android.permission.INTERNET' The app is allowed to make outbound network connections. This is relevant because network traffic to an ad-related domain was also observed. Permission alone does not prove data exfiltration or malicious communication. Overlay capability Manifest permission: 'android.permission.SYSTEM_ALERT_WINDOW'; component name: 'AdOverlayService' The app can request/display overlays over other apps. In combination with 'AdOverlayService', this is consistent with ad overlays or pop-up style UI. Overlay permission is security-relevant because it can be abused for deceptive UI, clickjacking, or phishing-like behavior. The artifacts do not show that malicious overlays were displayed, only that the capability and an overlay-named service exist. Notification policy access Manifest permission: 'android.permission.ACCESS_NOTIFICATION_POLICY' The app can request access to notification/DND policy controls. This is a sensitive permission because it may affect notification behavior or Do Not Disturb settings. No evidence is provided that the permission was granted by the user or that notification settings were changed. Limited exported component exposure Manifest components: 'MainActivity (exported=false)', 'AdOverlayService (exported=false)' These listed Based on the provided artifacts, I can analyze and report the following security-relevant findings:
R-033755AE	AND-009	### Manifest Analysis: - **Permissions:** - 'android.permission.ACCESS_FINE_LOCATION': The app has permission to access precise location information. This is a high-risk permission as it allows the application to determine the user's exact location. - 'android.permission.ACCESS_BACKGROUND_LOCATION': This additional permission allows the application to track the user's location even when the app is not in use, which can be used for tracking or surveillance purposes and poses significant privacy risks. - 'android.permission.INTERNET': The app has permission to access the internet, which could potentially allow it to communicate with remote servers. - **Components:** - 'WeatherActivity (exported=false)': This component does not have its exported flag set to true, meaning it can only be accessed by other components within the same application. However, this is less of a security concern compared to permissions and network activities. - 'LocationUpdateService (exported=false)': Similar to the previous case, this service cannot be directly triggered from outside the app without additional context.
R-04FB6B56	AND-025	Here are the security-relevant findings supported by the artifacts, with a clear separation between **directly observed facts** and **inferences**. ## 1) App has network capability and is contacting an external server **Directly observed** - Manifest includes only one permission: 'android.permission.INTERNET'. - Traffic log shows outbound traffic on '2026-01-25T13:00:00Z' to 'news-cdn.example.com' with '12000' bytes. - 'news-cdn.example.com' resolves in the provided indicators to '198.51.100.50'. **Inference** - The app is designed to communicate over the network, and at least one live network exchange occurred with a remote host. - The observed traffic is consistent with the app fetching online content, likely news/article data, but the content of the traffic is not known from these artifacts. --- ## 2) The app appears to have a small declared attack surface for inter-app interaction **Directly observed**

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-054C5DF3	AND-015	Below are the security-relevant findings I can support from the artifacts, with a clear separation between **directly observed facts** and **inferences**. ## 1) The app appears to be an antivirus-themed app with strong indicators of scareware behavior **Directly observed** - Package name: `com.security.antivirusfree` - Strings include: - `fake_threat_detected` - `uninstall_blocked_message` - `pay_to_unlock_endpoint` **Supported inference** - The package name and strings strongly suggest the app presents itself as a security/antivirus product while potentially generating false threat alerts. - The presence of `fake_threat_detected` is especially consistent with a deceptive "scareware" model intended to frighten the user into taking action. - `uninstall_blocked_message` suggests the app may display messaging that discourages removal.
R-059262D5	AND-023	## 2) The app requests device-admin capability, which can be used to resist removal or control the device # Forensic Analysis Report: com.finance.budgettrackerapp ## Scope & Limitations This analysis is based solely on the static artifacts provided. No dynamic execution data, full APK bytecode, or filesystem contents were available. Findings are separated below into **directly observed** and **inferred** categories to avoid overstating conclusions. --- ## Directly Observed Findings ### 1. Certificate is self-signed while claiming to be a financial institution - **Observed**: `self_signed: true` with `issuer = "CN=TrustedBank Financial Corp, O=TrustedBank Financial Corp, C=US"`. - **Significance**: Android app signing certificates are "normally" self-signed, so self-signing alone is not anomalous. However, the certificate's subject/issuer impersonates a named financial brand ("TrustedBank Financial Corp"). A legitimate corporation's identity claim in a certificate carries **no trust value when self-signed** — there is no CA validation binding this identity. This is a **red flag for brand impersonation / spoofing**, especially combined with the finance- Based on the provided artifacts, here are the security-relevant findings: **Permission Usage**: - The app `com.utility.cloudsyncapp` requests the `android.permission.INTERNET` permission. - **Observation**: This directly indicates that the application has the ability to access and communicate over the internet. **Component Export Status**: - The main component, `SyncActivity`, is marked as not exported (`exported=false`). - **Inference**: While this suggests that the activity is intended for internal use only and should not be accessible via an intent from another app, it does not guarantee that the application cannot be exploited. Android's security model can still allow certain components to interact with each other through intents or broadcasts. **Strings and Domain Names**: - The strings `sync_endpoint_primary` and `backup-relay.example.com` are observed in the `strings` array. - **Observation**: These suggest that there is a network endpoint named `sync-primary.example.com` used for synchronization, though it's not directly mentioned in the provided artifacts. Additionally, the domain name `backup-relay.example.com` is noted but does not have direct evidence of usage.
R-0828B43E	AND-021	
R-09A4EDB9	AND-017	# Forensic Analysis Report: com.utility.deviceassist ## Summary of Assessment The artifacts show characteristics consistent with **surveillance/stalkerware or spyware**, though the analysis below carefully separates direct observations from inferences. --- ## Directly Observed Findings ### 1. Permission Set **Observed**: The manifest requests `RECORD_AUDIO`, `BIND_ACCESSIBILITY_SERVICE`, `ACCESS_FINE_LOCATION`, and `INTERNET`. **Significance**: This combination is directly readable from the manifest. `BIND_ACCESSIBILITY_SERVICE` combined with `RECORD_AUDIO` and fine location is a high-risk grouping — accessibility services can observe on-screen content and user interactions across all apps.
R-0D2194C8	AND-015	# Forensic Analysis: com.security.antivirusfree ## Directly Observed Findings **1. Device Administrator Abuse Pattern** - The app requests `BIND_DEVICE_ADMIN` permission and registers `AdminLockReceiver` with an intent-filter for `DEVICE_ADMIN_ENABLED`. - This is the standard mechanism apps use to gain Device Admin privileges, which (once granted by the user) makes uninstallation significantly harder — Android requires the user to manually revoke admin rights before uninstall is permitted. - **Directly observed**: the manifest declaration and receiver registration. - **Inferred**: actual admin activation depends on user interaction (not present in the artifacts), but the app is structurally equipped to resist removal. **2. Ransomware/Scareware Indicators via Strings** - String resources `fake_threat_detected`, `uninstall_blocked_message`, and `pay_to_unlock_endpoint` are directly present in the app's string table. - These names strongly suggest the app is designed to: - Fabricate malware/threat detections (fake_threat_detected) rather than perform genuine scanning. - Display messaging that discourages/blocks uninstallation (uninstall_blocked_message) — consistent with the Device Admin abuse noted above.

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-10BB81A3	AND-028	# Digital Forensic Analysis Report ## Application: com.utility.calculatorpro --- ## Security-Relevant Findings ### 1. **INTERNET Permission Granted (Direct Observation)** - **Finding**: The application manifest declares `android.permission.INTERNET` - **Significance**: Medium - An unexpected permission for a basic calculator utility - **Observation vs. Inference**: - **Direct**: Permission is explicitly requested in the manifest - **Inferred**: Functionality likely requires network access, but purpose is unclear without additional evidence - **Note**: No network traffic or connectivity logs are present in the artifacts, preventing determination of actual usage
R-129372EC	AND-017	### 2. **Exported Component Status (Direct Observation)** Here are the security-relevant findings supported by the artifacts, with clear separation between what is directly observed and what is inferred. ## 1) The app requests multiple high-risk permissions **Directly observed** - `android.permission.RECORD_AUDIO` - `android.permission.BIND_ACCESSIBILITY_SERVICE` - `android.permission.ACCESS_FINE_LOCATION` - `android.permission.INTERNET` **Security-relevant implication** - The app is technically capable of: - recording audio, - obtaining precise location, - sending data off-device, - and using an Accessibility Service, which can observe UI interactions and on-screen content in many scenarios.
R-14897EAC	AND-005	# Forensic Analysis: com.android.systemupdate.helper ## Directly Observed Findings **1. Package name masquerading as system component** - Package name `com.android.systemupdate.helper` mimics AOSP naming conventions, but this is not a genuine system package (system apps use signature/privileged install paths, not sideloaded APKs with self-signed certs). **2. Device Administrator abuse capability** - Manifest declares `BIND_DEVICE_ADMIN` permission. - `AdminReceiver` component is exported=true and registers for `DEVICE_ADMIN_ENABLED`. - This is directly observed: the app is designed to request Device Admin privileges, which — once granted by a user — can enable lock-screen control, forced password resets, or device wipe, depending on policies invoked elsewhere in code (not shown in these artifacts). **3. Persistence mechanism** - `BootReceiver` is exported and filters on `BOOT_COMPLETED`, directly indicating the app is designed to auto-start after device reboot without user
R-14DD2BD2	AND-008	# Forensic Analysis: com.creative.photoeditorpro ## Directly Observed Findings **Permissions (manifest)** - App declares `INTERNET`, `READ_EXTERNAL_STORAGE`, and `WRITE_EXTERNAL_STORAGE`. These are consistent with a photo editor's stated function (loading/exporting images, network use for ads/updates). No unusual permissions (e.g., contacts, SMS, location, camera microphone) are present in the artifact. **Components** - Only one component listed, `EditorActivity`, with exported=false. As given, this means the activity cannot be launched by other apps directly via implicit/explicit intent from external packages, reducing inter-app attack surface — but this is a single-component manifest excerpt, not a full component list (no launcher activity, services, receivers, or providers are shown, which is atypical for a complete manifest and suggests this is a partial extraction). **Strings** - `com.adnetwork.sdk.banner` indicates the app bundles a third-party advertising SDK. `filter_applied` and `export_image` are consistent with core photo-
R-1533F62F	AND-012	Here are the security-relevant findings that can be supported from the provided artifacts, with clear separation between what is directly observed and what is inferred. ## 1) The app is built for call recording / phone-state monitoring **Directly observed** - Package name: `com.utility.callrecorder` - Strings include: - `call_recording_saved` - `phone_state_listener` - Permissions include: - `android.permission.RECORD_AUDIO` - `android.permission.READ_PHONE_STATE` **Reasonable inference** - The app is intended to record audio associated with calls and monitor call state (e.g., ringing, active call, idle). - The string `call_recording_saved` suggests it saves recorded call audio or related output.

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-1669A6BF	AND-007	# Forensic Analysis: com.productivity.quicknotes ## Directly Observed Findings **1. Permission/Functionality Mismatch (READ_SMS)** - **Observed:** The manifest declares a single permission: `android.permission.READ_SMS`. - **Observed:** The app is branded/named as a notes/productivity app (`quicknotes`), with strings suggesting note functionality (`note_saved`, `note_search_index`) and a single notes component (`NotesActivity`). - **Significance:** A note-taking application has no legitimate functional need to read SMS messages. This is the most security-relevant finding — an over-privileged, dangerous-category permission inconsistent with the app's stated purpose. This pattern is common in spyware/data-exfiltration or credential/OTP-theft scenarios (SMS contains 2FA codes, banking notifications, etc.). **2. App Component Structure** - **Observed:** Only one component listed, `NotesActivity`, with `exported=false`. - **Significance:** The exported=false setting means this activity is not directly launchable by other apps — a reasonable, non-vulnerable configuration for this component. No exported receivers/services are listed in the provided evidence. Based on the provided artifacts, here are the security-relevant findings:
R-1818155C	AND-026	### Manifest Analysis: - **Permissions**: - The app requests `android.permission.INTERNET`, which is a standard permission for most applications and does not necessarily indicate a security risk by itself. - It also requests both `android.permission.CAMERA` and `android.permission.RECORD_AUDIO`. These permissions allow the app to access sensitive user data such as camera feeds and audio recordings, which could be used for unauthorized surveillance. This is **observed** from the manifest. - **Components**: - The `ChatActivity` component has its `exported` attribute set to false, meaning it cannot be directly invoked by other apps without an explicit intent. However, this does not guarantee that sensitive data will not leak through other mechanisms. - The `MessageService` is also marked as non-exported. While non-exported services can still run in the background and potentially perform security-sensitive operations, their interaction with exported components or APIs would need to be analyzed further. ### Strings Analysis: Based on the provided artifacts, here are the security-relevant findings:
R-1D6689BD	AND-008	1. **Permissions**: - **Direct Observation**: The app requires permissions to access and modify external storage (`READ_EXTERNAL_STORAGE` and `WRITE_EXTERNAL_STORAGE`) as well as internet access. - **Inference**: These permissions can be used for unauthorized data exfiltration or modification of user files, posing a risk to device security. 2. **Component Export Status**: - **Direct Observation**: The `EditorActivity` component is not marked as exported in the manifest. - **Inference**: This suggests that by default, this activity cannot be invoked from other apps. However, if it can be bypassed or manipulated through malicious intent, it could still pose a security risk. 3. **Strings**: - **Direct Observation**: The app includes strings such as "filter_applied", "com.adnetwork.sdk.banner", and "export_image". - **Inference**: These strings indicate that the application has functionalities related to image filters, advertising from an ad network, and exporting images. This suggests potential data leakage or manipulation risks.
R-23FDA9A3	AND-005	# Digital Forensic Analysis Report ## SECURITY-RELEVANT FINDINGS ### 1. **Suspicious Device Administrator Registration** **Severity: HIGH** **Direct Observations:** - `AdminReceiver` component is exported (exported=true) - Intent filter for `android.app.action.DEVICE_ADMIN_ENABLED` is present - App requests `android.permission.BIND_DEVICE_ADMIN` permission - String artifact "device_admin_lock" suggests device locking functionality **Analysis:** The combination of an exported admin receiver with device admin permissions enables the app to obtain elevated system privileges. Once activated, device admin status allows:
R-2408F8EF	AND-009	# Forensic Analysis: com.weather.dailyforecast ## Directly Observed Findings **1. Location Permissions** - The manifest explicitly requests `ACCESS_FINE_LOCATION` and `ACCESS_BACKGROUND_LOCATION`. - Combined with `INTERNET` permission, the app has the technical capability to collect precise location data even when not in active use and transmit it externally. - Observed string `location_update_interval` corroborates that location collection is a designed, recurring feature (not a one-time permission request). **2. Component Exposure** - Both `WeatherActivity` and `LocationUpdateService` are marked `exported=false`. - This directly indicates these components cannot be invoked by other apps on the device via implicit intents, reducing local attack surface (e.g., no other app can trigger `LocationUpdateService` directly). **3. Certificate**

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-25275473	AND-007	Based on the provided artifacts, we can identify several security-relevant findings: Manifest Permissions: Direct Observation: The app has been granted the 'android.permission.READ_SMS' permission. Security Finding: This indicates that the application has the ability to read SMS messages from the device. This is a concerning permission because it allows the app to access sensitive data such as personal text communications, which could be used for various malicious purposes, including harvesting phone numbers or stealing private information. Components: Direct Observation: The manifest contains an activity named 'NotesActivity' that is not exported. Security Finding: While the component 'NotesActivity' is marked as non-exported, this does not necessarily mean it is secure. Non-exported components can still pose risks if they have access to sensitive data or perform potentially harmful operations. The lack of explicit security measures for internal components should be noted. Strings: Direct Observation: Strings such as "note_saved" and "note_search_index" are present.
R-25552207	AND-004	# Digital Forensic Analysis: com.privacy.freevpnturbo ## Security-Relevant Findings ### 1. Inconsistent Application Purpose vs. Permissions Observation: The app declares itself as a VPN application (string resources: "vpn_connect", "vpn_server_list") but requests 'READ_CONTACTS' permission. Finding: VPN applications typically do not require contact access. The presence of 'contact_sync_helper' in string resources combined with 'READ_CONTACTS' permission suggests potential "unauthorized contact data collection" beyond stated VPN functionality. Risk Level: HIGH - Indicates possible data harvesting behavior misaligned with advertised privacy function. --- ### 2. Certificate Validity Expiration
R-2BEB4295	AND-015	Based on the provided artifacts, here are the security-relevant findings: ### Manifest Analysis Finding 1: Device Administration Permission Observation: The app's manifest includes a 'BIND_DEVICE_ADMIN' permission. Implication: This permission allows the application to request device administration privileges. With these privileges, the app can perform operations such as locking the screen or wiping data without user consent after being enabled by the user. Finding 2: Internet Permission Observation: The app's manifest includes an 'INTERNET' permission. Implication: This permission allows the application to connect to the internet. While necessary for many legitimate applications, it could be used to send data or requests to external servers, which may indicate potential malicious activities. Finding 3: Component Analysis Component: ScanActivity (exported=false)
R-325EBE54	AND-015	## Security-relevant findings from the provided artifacts ### 1. App presents as an antivirus/security product Directly observed: - Package name: 'com.security.antivirusfree' - Component: 'ScanActivity' Inferred: - The app is likely intended to appear as a free antivirus or security scanner to the user. Not established by evidence: - Whether it performs any legitimate antivirus scanning. - Whether the app was opened or used by the device owner. ---
R-32834152	AND-022	# Digital Forensic Analysis: com.utility.voicememoapp ## Security Findings ### 1. Appropriate Permission Scoping ✓ Observation: The app declares only two permissions: 'RECORD_AUDIO' - necessary for voice memo functionality 'INTERNET' - required for potential cloud sync/backup features Assessment: No evidence of permission over-claiming (e.g., no SMS, contact, location, or camera permissions requested). This is consistent with the stated functionality. --- ### 2. Absence of Network Activity Data Observation:

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-36123B24	AND-003	# Forensic Analysis Report: com.tools.qrscannerfree ## Summary The application presents as a "QR Scanner (Free)" but exhibits characteristics consistent with premium SMS fraud / toll fraud potential. Below findings are separated into direct observations and supported inferences. --- ## Directly Observed Findings ### 1. Permission-to-Function Mismatch Observed: The manifest declares <code>'SEND_SMS'</code> and <code>'READ_SMS'</code> permissions alongside <code>'CAMERA'</code>. - <code>'CAMERA'</code> is consistent with the app's stated QR-scanning purpose. - <code>'SEND_SMS'</code> and <code>'READ_SMS'</code> have no legitimate functional justification for a QR scanner.
R-370C45CC	AND-008	# Digital Forensic Analysis Report ## Package: com.creative.photoeditorpro --- ## Security-Relevant Findings ### 1. Certificate Validity Expiration (OBSERVED) Severity: Medium Confidence: High Observation: - Certificate validity period: 2023-04-01 to 2025-04-01 - Traffic log timestamp: 2026-01-20T14:00:00Z - The certificate had expired approximately 9 months prior to observed network activity Forensic Significance:
R-381B08DC	AND-009	## Summary Assessment Nothing in this artifact set supports a finding of malicious behavior. The evidence is consistent with a legitimate weather application, with a small number of items worth documenting and a significant caveat about the provenance of the data itself. --- ## Directly Observed 1. Sensitive permission set, minimal but high-impact - Declared: <code>'ACCESS_FINE_LOCATION'</code>, <code>'ACCESS_BACKGROUND_LOCATION'</code>, <code>'INTERNET'</code>. - <code>'ACCESS_BACKGROUND_LOCATION'</code> is the most privacy-significant item present: it permits precise location collection while the app is not in the foreground. - Notably absent: no <code>'READ_CONTACTS'</code>, <code>'READ_SMS'</code>, <code>'RECORD_AUDIO'</code>, <code>'CAMERA'</code>, <code>'READ_EXTERNAL_STORAGE'</code>, <code>'QUERY_ALL_PACKAGES'</code>, <code>'RECEIVE_BOOT_COMPLETED'</code>, <code>'SYSTEM_ALERT_WINDOW'</code>, or accessibility-service usage. There is no over-permissioning pattern.
R-39A54C3B	AND-028	Based on the provided artifacts, I can draw several security-relevant findings. Here is a detailed analysis: ### Manifest Analysis 1. Package Name and Permissions: - Observation: The application has a package name <code>'com.utility.calculatorpro'</code> and requests only one permission: <code>'android.permission.INTERNET'</code>. - Inference: This suggests the app primarily uses internet access for functionality, possibly to fetch updates or communicate with servers. However, it does not request broader permissions that could compromise privacy or system security. 2. Components: - Observation: The manifest lists one component named <code>'CalcActivity'</code> and specifies that this activity is not exported (i.e., it cannot be launched by other applications). - Inference: This indicates the app does not pose a direct risk of being maliciously or unintentionally accessed by other applications. However, if an exploit were to occur within <code>'CalcActivity'</code>, it would remain confined to the app's own execution environment. ### Strings Analysis 1. String References:
R-3B7ECF93	AND-025	## Scope note This assessment is based solely on the artifacts provided. There is no decompiled code, no APK hash, no install-source or timestamp metadata, and only a single traffic-log entry. Conclusions about behavior are therefore constrained — most of what follows is about what is present in the package, not what the app was observed doing. --- ## Findings ### 1. Hardcoded secondary domain not accounted for by observed traffic — primary finding, unresolved Directly observed: The string table contains <code>'suspicious-relay.example.com'</code> alongside the apparently functional <code>'news-cdn.example.com'</code>. The string <code>'config_backup_url'</code> also appears, adjacent to <code>'articles_fetch'</code>. Directly observed: The <code>'network_indicators'</code> entry for <code>'suspicious-relay.example.com'</code> is sourced from <code>'strings'</code>, not from <code>'traffic_log'</code>. The only logged

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-3C12F7C1	AND-004	# Forensic Analysis: com.privacy.freevpnturbo ## Directly Observed Findings **1. Permission-to-function mismatch (contacts)** - The manifest declares `android.permission.READ_CONTACTS`. - A string resource `contact_sync_helper` is present, suggesting code exists to read/sync contact data. - **Observed fact:** A VPN application requests contact access and contains a named helper string related to contact syncing. - **Inference (not directly proven):** This permission is not necessary for core VPN functionality (establishing tunnels, routing traffic). Its presence, combined with the `contact_sync_helper` string, is suggestive of data collection/exfiltration behavior beyond the app's stated purpose. This is a plausible inference from naming conventions, not a confirmed data flow — no code logic, API calls, or actual contact data transmission is shown in the artifacts. **2. READ_PHONE_STATE permission** - **Observed fact:** Permission is declared in the manifest. - **Inference:** This permission is commonly used to obtain device identifiers (IMEI, subscriber ID) for tracking/fingerprinting, or legitimately for detecting call interruptions to a VPN session. The artifacts do not show which purpose applies — no corresponding string, code reference, or network transmission of an
R-3FE285FD	AND-025	## Forensic security findings for `com.utility.newsreaderapp` ### 1. App has network capability - **Directly observed:** The manifest requests only one permission: `android.permission.INTERNET`. - **Security relevance:** The app is capable of making outbound network connections. - **Inference:** Network access is consistent with a news reader app fetching articles, but it also enables possible data transmission if the app were malicious or compromised. - **Limitations:** No evidence here that the app has permissions for SMS, contacts, location, microphone, camera, or external storage. --- ### 2. Observed network activity to `news-cdn.example.com` - **Directly observed:** - `traffic_log` records communication on `2026-01-25T13:00:00Z`. - Destination domain: `news-cdn.example.com`. - Data volume: `12000` bytes.
R-43056BD9	AND-016	# Digital Forensic Analysis Report ## Application: com.utility.smsbackuptool --- ## CRITICAL SECURITY FINDINGS ### 1. **SMS Interception Capability (HIGH SEVERITY)** **Direct Observation:** - Manifest declares `SmsInterceptReceiver` component with `exported=true` - Component has intent-filter for `android.provider.Telephony.SMS_RECEIVED` - App holds `RECEIVE_SMS` permission **Security Implication:** This configuration allows the receiver to intercept all incoming SMS messages on the device. The `exported=true` setting means other applications could potentially trigger this receiver, though the primary risk is the app's own SMS access.
R-43ED9D99	AND-028	# Forensic Analysis Report: com.utility.calculatorpro ## Scope Note This analysis is limited strictly to the provided artifacts. Several fields are explicitly truncated during extraction, which materially limits the conclusions that can be drawn. I have separated **direct observations** from **inferences** and flagged evidentiary gaps. --- ## Directly Observed Findings ### 1. Requested permissions are minimal - **Observed:** The manifest declares a single permission: `android.permission.INTERNET`. - **Support:** Directly listed in `manifest.permissions`. - **Note:** For a calculator, network access is not functionally required, but INTERNET alone is a low-risk, extremely common permission. This is a point of interest, not evidence of malicious behavior.
R-59BB0209	AND-022	Based on the extracted application artifacts, here are the security-relevant findings: 1. **Permissions Analysis:** - **Direct Observation:** The app has been granted two permissions: - `RECORD_AUDIO`: This permission allows the app to record audio. - `INTERNET`: This permission enables internet access for the app. - **Security Finding:** The app has broad permissions that could be exploited to gather sensitive user data and potentially execute unauthorized actions, such as recording conversations or accessing other online resources. 2. **Component Analysis:** - **Direct Observation:** There is a single component named `MemoActivity` which is not exported. - **Security Finding:** The absence of exporting any components (other than the default activities) suggests that the app may not be overly concerned with privacy or external access, but this does not mitigate the risks posed by the permissions it holds.

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-5B24C212	AND-010	## Summary Assessment Based solely on the supplied artifacts, this app presents as "internally consistent with a legitimate fitness/wearable companion app". No indicator in this evidence set supports a malware or spyware conclusion. There are, however, several items worth documenting, plus significant evidentiary gaps that prevent a clean "benign" determination. --- ## 1. Directly Observed Findings **1.1 Permission set is narrow and purpose-consistent** - Declared: 'BLUETOOTH_CONNECT', 'ACTIVITY_RECOGNITION', 'INTERNET'. - Notably "absent": location ('ACCESS_FINE/COARSE_LOCATION'), contacts, SMS, call log, camera, microphone, storage, 'QUERY_ALL_PACKAGES', accessibility, device admin, 'RECEIVE_BOOT_COMPLETED'. - This is a minimal permission footprint. There is no over-permissioning in this manifest.
R-5D1394F9	AND-001	# Forensic Analysis Report: com.brightapps.flashlightpro ## Summary The app presents as a "flashlight" utility but exhibits characteristics consistent with data-collection/exfiltration behavior. Findings below distinguish "directly observed" evidence from "inferred" conclusions. --- ## Findings ### 1. Permission set disproportionate to stated function - **Observed:** Manifest declares 'READ_CONTACTS', 'ACCESS_FINE_LOCATION', 'INTERNET', and 'CAMERA'. - **Inferred:** A flashlight app plausibly needs 'CAMERA' (to control the camera flash LED). 'READ_CONTACTS', 'ACCESS_FINE_LOCATION', and 'INTERNET' have no legitimate connection to flashlight functionality. This is a classic over-permissioning red flag suggesting hidden functionality. - **Confidence:** High that permissions exist (observed); high that they are excessive for the claimed purpose (well-supported inference).
R-606AD18A	AND-012	# Forensic Analysis: com.utility.callrecorder ## Directly Observed Findings **1. App functionality aligns with stated purpose** - Permissions ('RECORD_AUDIO', 'READ_PHONE_STATE') and strings ('call_recording_saved', 'phone_state_listener') are consistent with a legitimate call-recording utility. - 'CallDetectionService' likely uses 'READ_PHONE_STATE' to detect call events (inferred from naming/permission correlation, not from decompiled logic — no code was provided). **2. No exported attack surface** - Both components ('RecorderActivity', 'CallDetectionService') are 'exported=false'. This means other apps cannot directly launch/bind to them via explicit Intents, reducing inter-app attack surface. **This is directly observed** from the manifest. **3. No network activity detected** - 'network_indicators' and 'traffic_log' are both empty. This means "no evidence of network communication was captured in this dataset" — it does not
R-60A25623	AND-017	Based on the provided artifacts, several security-relevant findings can be made: ### Manifest Analysis: - **Permissions**: - 'RECORD_AUDIO': The app has permission to record audio from the device. This could indicate potential privacy risks if the application is used for malicious purposes. - 'BIND_ACCESSIBILITY_SERVICE': This permission allows the app to bind itself to accessibility services, which can be used to control or monitor user interactions with other apps, posing significant security and privacy concerns. - 'ACCESS_FINE_LOCATION': The app has access to fine-grained location data. This is a high-risk permission as it could allow tracking of the device's movements without the user's knowledge or consent. - 'INTERNET': This permission enables internet communication, which is common for most apps but should be noted in conjunction with other permissions. - **Components**: - 'AssistActivity (exported=false)': The activity does not have an exported component, meaning it cannot be directly launched by external applications. However, this does not mitigate the risks associated with its installed permissions. - 'MonitorService (exported=false, launched by BootReceiver)': This background service is launched at boot and operates without being directly exportable to
R-61FA9E91	AND-010	# Digital Forensic Analysis Report ## Application: com.health.fittrackpro --- ## SECURITY-RELEVANT FINDINGS ### 1. **Certificate Validity Expired** **Severity: HIGH** **Direct Observation:** - Certificate validity period: 2023-08-01 to 2025-08-01 - Traffic log timestamp: 2026-02-02T07:30:00Z - The certificate expired approximately 6 months before observed network activity **Security Implication:**

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-6406F9F0	AND-023	Based on the provided artifacts, I can identify several security-relevant findings: ### Manifest Analysis Observation: - Package Name: `com.finance.budgettrackerapp` (Directly Observed) - Permissions Requested: - `android.permission.INTERNET` (Directly Observed) Inference: - The app requests the ability to access the internet, which could be used for various purposes such as sending data to a remote server or downloading resources. ### Strings Analysis
R-6EDBD17	AND-002	Observation: Based on the provided artifacts, we can identify several security-relevant findings: ### Manifest Analysis: - Permissions: - `android.permission.INTERNET`: This permission is standard for many apps and does not necessarily indicate malicious behavior alone. - `android.permission.SYSTEM_ALERT_WINDOW`: This indicates that the app has the ability to display overlays on top of other applications, which could be used for privacy invasion or malicious purposes like displaying unsolicited ads or notifications. - `android.permission.ACCESS_NOTIFICATION_POLICY`: This permission allows the app to modify and manipulate system notifications. This can be used for deceptive or harmful activities such as silencing critical system notifications. - Components: - `MainActivity (exported=false)`: The main activity is not exported, which means it cannot be started by other applications directly. - `AdOverlayService (exported=false)`: Similarly, this service is also not exported and thus does not pose an immediate risk of being triggered from outside the app. ### Strings Analysis:
R-7098B81F	AND-022	Security-relevant findings supported by the artifacts Finding Directly observed evidence Inference / security relevance --- --- --- App can record audio Manifest requests `android.permission.RECORD_AUDIO` The app has the capability, if granted by the user/device policy, to access the microphone and create audio recordings. This is consistent with a voice memo app, but it is also privacy-sensitive. App can access the Internet Manifest requests `android.permission.INTERNET` The app has the capability to make network connections. Combined with `RECORD_AUDIO`, the app technically could transmit recorded audio, but the provided artifacts do not show that it did so. No observed network destinations or traffic `network_indicators: []`; `traffic_log: []` There is no evidence in these artifacts of contacted domains, IPs, URLs, or captured network traffic. This does not prove the app never communicated; it only means no network indicators or traffic were present in the provided extraction/logs. Limited exposed component surface Manifest lists `MemoActivity (exported=false)` The listed activity is not exported, meaning other apps should not be able to directly launch it via Android inter-app intents. This reduces external attack surface for that component. No exported services, receivers, or providers are shown. App appears to include voice memo UI functionality Strings include `memo_list_view`, `memo_delete`, `app_settings_screen` These strings are consistent with a memo-listing/deletion/settings interface. This supports the app's apparent purpose as a voice memo utility, but does not prove benign behavior by itself.
R-7235A37B	AND-021	Forensic Analysis: com.utility.cloudsyncapp ## Directly Observed Findings 1. Permissions & Attack Surface - The app declares only `INTERNET` permission — no access to contacts, storage, location, SMS, etc. is requested in the manifest as extracted. - The single listed component, `SyncActivity`, has `exported=false`, meaning it cannot be directly invoked by other apps on the device. This limits (but does not eliminate — see below) inter-app attack surface. 2. Hardcoded Network Indicator - The string `backup-relay.example.com` is present in the app's strings table and is also independently listed in `network_indicators` with a resolved IP (`203.0.113.110`), sourced from strings analysis (i.e., static extraction, not observed live traffic). 3. Certificate - The app's signing certificate is issued by `CN=CloudSync Inc, O=CloudSync, C=US`, is not self-signed (per the `self_signed: false` field), and has a validity window of 2023-06-01 to 2025-06-01.
R-7C262E10	AND-018	Digital Forensic Analysis Report Package: com.creative.livewallpaperhd --- ## CRITICAL FINDINGS ### 1. Cryptocurrency Mining Activity (HIGH CONFIDENCE) Direct Observations: - Manifest contains `MiningWorkerService` component - String artifacts include: `mining_pool_connect`, `hashrate_report`, `cpu_throttle_disable` - Network traffic to `pool.example.com` (203.0.113.90) with consistent hourly connections (~2,100-2,300 bytes each) - Service launches automatically via `BootReceiver` on device startup Inference:

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-82FBE8F9	AND-018	### Security-Relevant Findings #### 1. **Permissions** - **Observed**: The app `com.creative.livewallpaperhd` requests the following permissions: - `android.permission.INTERNET`: This permission allows the application to access and communicate over the network, which is necessary for its intended function as a live wallpaper that likely fetches data or updates from remote servers. - `android.permission.WAKE_LOCK`: This permission enables the app to keep the screen on or prevent the device from going into sleep mode. This can be used by the application to ensure it continues running background processes, which could potentially drain battery and perform unauthorized activities. - `android.permission.RECEIVE_BOOT_COMPLETED`: This permission allows the app to run a service immediately after the system boots up. While this is a legitimate permission for an application that needs to start automatically upon boot (e.g., live wallpapers), it also means the app can be started before any security checks, which might allow it to gain unauthorized access early in the device's lifecycle. #### 2. **Components** - **Observed**: The manifest lists two components: - `WallpaperService`: This component is not exported and is likely a legitimate wallpaper service. - `MiningWorkerService`: This component is also not exported but is launched by a boot receiver (`BootReceiver`). Given that the `MiningWorkerService` is
R-84741BE2	AND-010	# Forensic Analysis: com.health.fittrackpro ## Directly Observed Findings **1. Permissions (from manifest)** - App requests `BLUETOOTH_CONNECT`, `ACTIVITY_RECOGNITION`, and `INTERNET` - These align with a fitness-tracking app's stated purpose (BLE device pairing, step/activity data, network sync) - No location, contacts, SMS, camera, or storage permissions are present in the extracted list **2. Components** - Both `DashboardActivity` and `BleSyncService` are marked `exported=false` - This means these components cannot be launched or bound to directly by other apps on the device — reduces attack surface for inter-app component hijacking (IAC), assuming this is the complete component list **3. Code strings** - Strings `step_count_sync`, `ble_device_pair`, `heart_rate_reading` are consistent with fitness/health tracking functionality
R-88AB0089	AND-020	# Forensic Analysis: com.utility.clipboardmanagerpro ## Summary Assessment The artifacts are strongly consistent with a `clipboard-hijacking cryptocurrency stealer` (commonly called a "clipper"). Below I separate what is directly observed from what is inferred. --- ## Directly Observed Findings ### 1. Cryptocurrency-related clipboard manipulation strings **Observed**: The strings table contains `clipboard_watch_loop`, `btc_address_regex`, `eth_address_regex`, and `clipboard_replace_content`. **Directly supported**: The app contains code/resource identifiers referencing (a) monitoring the clipboard in a loop, (b) regular expressions for Bitcoin and Ethereum addresses, and (c) replacing clipboard content.
R-8B6977EC	AND-019	# Forensic Analysis: com.family.safetytrackerpro ## Directly Observed Findings **Permissions (from manifest)** - App requests `ACCESS_FINE_LOCATION` and `ACCESS_BACKGROUND_LOCATION` — enables continuous location collection even when not in foreground. - App requests `READ_SMS` — enables reading of SMS content (messages, likely sender/recipient metadata and body). - App requests `INTERNET` — enables exfiltration/sync of collected data to a remote host. **Components (from manifest)** - `TrackingService` is explicitly configured to be launched by `BootReceiver`. This is a directly observed persistence mechanism: the service will start automatically at device boot without user interaction. - Both `DashboardActivity` and `TrackingService` are `exported=false`, meaning they cannot be directly invoked by other apps on the device — this limits (but does not eliminate) attack surface from other local apps; it does not restrict what the app itself does with granted permissions.
R-90E3D7B2	AND-013	Based on the provided artifacts, we can extract several security-relevant findings. Here is a detailed analysis: ### Manifest Analysis: - **Package Name**: `com.utility.filemanagerpro` - **Observation**: The package name indicates that this application is likely a file management tool. - **Permissions**: - `android.permission.READ_EXTERNAL_STORAGE`: This permission allows the app to read files from external storage, which could be a security risk if misused. - **Observation**: Directly observed through the manifest. - `android.permission.WRITE_EXTERNAL_STORAGE`: This permission allows the app to write and modify files on external storage, posing a significant security threat if not properly managed. - **Observation**: Directly observed through the manifest. - `android.permission.MANAGE_EXTERNAL_STORAGE`: This is an enhanced storage permission that grants more control over the device's storage,

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-941B0366	AND-026	# Digital Forensic Analysis Report: com.social.chatmessengerapp ## Direct Observations ### 1. **Certificate Validity Expired** **Severity: HIGH** - **Observation:** Certificate validity period is "2023-12-01 to 2025-12-01" - **Evidence:** Traffic log shows activity on 2026-02-08, which is **after certificate expiration (2025-12-01)** - **Implication:** At time of traffic capture, the signing certificate had expired. This indicates either: - The application continued operating with an invalid certificate - Potential certificate pinning bypass or validation weakness - Possible repackaging or modification of the application ### 2. **Requested Permissions (Legitimate for Messaging App)** - **Observation:** Three permissions requested: - 'INTERNET' — required for network communication
R-9544AECC	AND-001	# Digital Forensic Analysis: com.brightapps.flashlightpro ## Critical Security Findings ### 1. **Unauthorized Contact Exfiltration** (HIGH CONFIDENCE) **Direct Observations:** - Manifest declares 'READ_CONTACTS' permission - Strings contain 'contact_upload_endpoint' reference - Network traffic to 'cdn-sync.example.com' totaling 21,532 bytes across two requests (14:32:07-14:32:09 UTC) **Assessment:** Strong indicator of contact data transmission. The specific string reference combined with declared contacts permission and outbound traffic creates a coherent pattern of potential contact harvesting. **Inference:** The timing (2-second interval, sequential requests) and data volume are consistent with contact list upload operations, though this cannot be definitively proven without network payload inspection.
R-966578D1	AND-014	### Security-Relevant Findings #### Manifest Analysis 1. **Permissions**: - **android.permission.INTERNET**: The app has the ability to access and send/receive data over the internet, which is a common permission but does not necessarily indicate malicious behavior. - **android.permission.SYSTEM_ALERT_WINDOW**: This permission allows the app to display floating windows on top of other applications. While it can be useful for overlay functionalities like notification managers or privacy screen protectors, its use can also allow unauthorized access to system alerts and notifications, potentially leading to user data interception or control over the UI. - **android.permission.BIND_ACCESSIBILITY_SERVICE**: This permission allows the app to bind to accessibility services, which can provide enhanced interaction with the Android operating system. However, it can be exploited to gain high-level access to screen content, keyboard events, and other sensitive information. 2. **Components**: - **HelperActivity (exported=false)**: The 'HelperActivity' is not exported, meaning that this activity cannot be started by other applications or broadcast
R-97813B94	AND-021	# Digital Forensic Analysis: com.utility.cloudsyncapp ## Direct Observations ### 1. **Certificate Validity Expiration** - **Finding**: The signing certificate expired on 2025-06-01 - **Evidence**: Certificate validity field shows "2023-06-01 to 2025-06-01" - **Current Status**: As of the traffic log timestamp (2026-02-05), this certificate is invalid - **Security Significance**: HIGH - The app is signed with an expired certificate, indicating either the device was compromised after certificate expiration or the app was installed prior to expiration and continued operating with an invalid signature ### 2. **Certificate Legitimacy** - **Finding**: Certificate is not self-signed and issued by CloudSync Inc (US-based) - **Evidence**: 'self_signed: false' and issuer CN/O/C fields - **Assessment**: This suggests the certificate was issued by a Certificate Authority, providing some legitimacy verification (though the expiration undermines this)
R-9A4ADA83	AND-002	# Digital Forensic Analysis Report ## Application: com.utility.batterysaverplus --- ## SECURITY-RELEVANT FINDINGS ### 1. **CRITICAL: Certificate Validity Expired** **Severity: HIGH** **Direct Observation:** - Certificate validity period: 2023-06-01 to 2025-06-01 - Traffic log timestamp: 2026-02-01T09:12:00Z - The certificate expired approximately 8 months before the observed network activity **Implication:**

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-A5FF9EC7	AND-013	## Summary Assessment The provided artifacts contain **no positive indicators of malicious behavior**. The security-relevant findings here are primarily about *capability* (what the app could do) and about *gaps in the evidence* (what these artifacts cannot tell you). I'd caution against treating this app as suspicious on the strength of this data alone. --- ## Finding 1 — Broad, unrestricted filesystem access **Directly observed:** The manifest declares <code>'READ_EXTERNAL_STORAGE'</code>, <code>'WRITE_EXTERNAL_STORAGE'</code>, and <code>'MANAGE_EXTERNAL_STORAGE'</code>. **Inferred:** <code>'MANAGE_EXTERNAL_STORAGE'</code> ("All Files Access") is the highest-privilege storage permission on Android 11+. If granted at runtime, it bypasses scoped storage and gives read/write access to nearly the entire shared storage volume, including other apps' media directories, documents, downloads, and camera output.
R-AB04572A	AND-020	# Forensic Analysis: com.utility.clipboardmanagerpro ## Directly Observed Findings **1. Cryptocurrency clipboard-hijacking capability (High Confidence)** - String artifacts <code>'btc_address_regex'</code>, <code>'eth_address_regex'</code>, and <code>'clipboard_replace_content'</code> are present in the binary alongside <code>'clipboard_watch_loop'</code> - This combination directly indicates code capable of pattern-matching BTC/ETH addresses in clipboard content and replacing them - **This is the classic signature of a "clipper" malware** — an app that swaps a copied crypto wallet address with an attacker-controlled address to hijack transactions **2. Persistence mechanism (Directly Observed)** - <code>'ClipboardMonitorService'</code> is explicitly configured to be launched by a <code>'BootReceiver'</code> - Component is <code>'exported=false'</code>, meaning it cannot be invoked by other apps — persistence is self-contained, not for inter-app abuse - This establishes the app runs continuously from device boot without user interaction **3. Network communication observed (Directly Observed)** Here are the security-relevant findings supported by the artifacts, with direct observations separated from inferences. ## 1) The app can access the network and shared external storage **Directly observed** - Package: <code>'com.utility.cloudbackupapp'</code> - Permissions: - <code>'android.permission.INTERNET'</code> - <code>'android.permission.READ_EXTERNAL_STORAGE'</code> **Implication / inference** - The app is technically able to read files from shared external storage and communicate over the network. - If it uses both permissions together, it could move user-accessible files off the device. That is a capability inference, not proof of misuse. ## 2) The exposed component surface appears limited **Directly observed** - Component listed:
R-B73F9D33	AND-024	# Forensic Analysis Report: com.utility.systemhelperservice ## Methodology Note Findings are separated into **directly observed** (present in the provided artifacts) and **inferred** (reasoned conclusions requiring caveats). This distinction matters for evidentiary reliability. --- ## 1. Permission & Capability Analysis **Directly observed:** - The app requests <code>'BIND_ACCESSIBILITY_SERVICE'</code>, <code>'SYSTEM_ALERT_WINDOW'</code>, and <code>'INTERNET'</code>. - A component <code>'OverlayAccessibilityService'</code> is declared. **Inferred (with caveats):** - This permission triad is a well-known combination abused by overlay/credential-stealing malware. Accessibility services can read on-screen content and
R-B7D51A2C	AND-014	# Forensic Analysis Report: com.utility.systemhelperservice ## Methodology Note Findings are separated into **directly observed** (present in the provided artifacts) and **inferred** (reasoned conclusions requiring caveats). This distinction matters for evidentiary reliability. --- ## 1. Permission & Capability Analysis **Directly observed:** - The app requests <code>'BIND_ACCESSIBILITY_SERVICE'</code>, <code>'SYSTEM_ALERT_WINDOW'</code>, and <code>'INTERNET'</code>. - A component <code>'OverlayAccessibilityService'</code> is declared. **Inferred (with caveats):** - This permission triad is a well-known combination abused by overlay/credential-stealing malware. Accessibility services can read on-screen content and
R-B8E8C9DD	AND-029	## Summary Assessment **Nothing in this artifact set supports a finding of malicious behavior.** The evidence is consistent with a benign, narrowly-scoped utility app. The security-relevant observations below are mostly *investigative leads* and *evidentiary gaps*, not indicators of compromise. I want to be explicit about that up front, because a calendar app with an ad SDK is an extremely common benign pattern and it would be easy to over-read it. --- ## Directly Observed (stated in the artifacts) # Observation Source field --- --- 1 Single permission requested: <code>'android.permission.INTERNET'</code> manifest.permissions 2 One declared component, <code>'CalendarActivity'</code>, with <code>'exported=false'</code> manifest.components 3 String reference to <code>'com.genericads.sdk'</code> strings 4 String <code>'event_created'</code> strings

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-B8EC7CF6	AND-006	### Security-Relevant Findings #### Manifest Analysis 1. **Permissions:** - **INTERNET**: The app has permission to access the internet, which is standard for many apps and not inherently suspicious. - **ACCESS_WIFI_STATE**: This allows the application to read the state of all Wi-Fi networks, which could be used for passive monitoring or data collection without active user consent. - **READ_EXTERNAL_STORAGE**: This grants the app full access to read any files on the device's external storage. While this is a common permission required by many apps, it can also allow the app to access sensitive information stored outside its own sandboxed directory. - **SYSTEM_ALERT_WINDOW**: This permission allows the app to display persistent windows over other applications without user intervention. This could be used for intrusive notifications or overlays that may bypass normal UI restrictions. 2. **Components:** - **GameActivity (exported=false)**: Indicates that this is a core activity of the application and is not exported, meaning it can only be launched by internal components. - **AdInjectorService (exported=false)**: This suggests there is an internal service for ad injection or other background tasks. The fact that it is also not
R-C52F3513	AND-005	### Security-Related Findings #### Manifest Analysis: 1. **Package Name:** - **Direct Observation**: The package name is 'com.android.systemupdate.helper'. - **Inference**: This suggests the app may be related to system updates or administration on an Android device. 2. **Permissions:** - **Internet Permission ('android.permission.INTERNET')**: - **Direct Observation**: The app requests internet access. - **Security Implication**: Allows the app to connect to external servers, potentially for downloading updates or checking for data from remote sources. - **Device Administration Permission ('android.permission.BIND_DEVICE_ADMIN')**: - **Direct Observation**: The app has permission to become a device administrator. - **Security Implication**: This grants extensive control over the device including locking functionality and other administrative tasks, which could be misused for unauthorized access or data exfiltration.
R-C6D76AF4	AND-025	Based on the provided application artifacts, I can report several security-relevant findings: #### Manifest Analysis: - **Permissions**: The app requests 'android.permission.INTERNET', which is a standard permission required for network communication and necessary for fetching articles from remote servers. - **Components**: The only exported component in the manifest is 'ReaderActivity'. This suggests that the application primarily functions as a news reader with limited interaction points, but it does not indicate any additional security risks directly. #### Strings Analysis: - **Strings Mentioned**: - "news-cdn.example.com": This domain appears multiple times and might be used for fetching news articles. However, its presence alone is not indicative of malicious activity without context. - "articles_fetch": Indicates that the app fetches articles, likely from 'news-cdn.example.com'. - "suspicious-relay.example.com" and "config_backup_url": These strings are marked as "suspicious," suggesting they may be used for unexpected or potentially harmful activities. However, their exact purpose cannot be determined without further context.
R-C727BD9B	AND-001	# Forensic Analysis: com.brightapps.flashlightpro ## Directly Observed Findings **1. Permission-functionality mismatch** - The manifest grants 'READ_CONTACTS', 'CAMERA', 'ACCESS_FINE_LOCATION', and 'INTERNET'. - A flashlight application's core function requires only camera/flash hardware access (typically 'CAMERA' or 'FLASHLIGHT' control). - 'READ_CONTACTS' and 'ACCESS_FINE_LOCATION' are **not functionally justified** by the observed string resources ('flash_toggle_on/off'), which reference only flashlight UI logic. **2. Evidence of contact exfiltration capability** - The string 'contact_upload_endpoint' is present alongside 'READ_CONTACTS' permission and 'INTERNET' permission. - This is **directly observed** as a string; it strongly **suggests** (inference) the app contains code paths to read the contacts database and transmit it externally, but the artifact set does not include decompiled code or a captured HTTP payload proving actual contact data was sent. **3. Network communication confirmed to a single external domain**
R-CC2FB5D8	AND-017	# Digital Forensic Analysis Report ## Application: com.utility.deviceassist --- ## CRITICAL FINDINGS #### 1. **Surveillance Capability - Audio Recording** **Severity: CRITICAL** **Direct Evidence:** - Manifest declares 'android.permission.RECORD_AUDIO' - String artifact references 'keystroke_log_buffer' - String artifact references 'screen_capture_interval' **Analysis:**

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-D857D326	AND-004	## Forensic Analysis — `com.privacy.freevpn turbo` ### Summary Assessment The artifacts show a self-described VPN application whose declared permissions and string constants indicate contact-harvesting capability unrelated to its stated function, while simultaneously lacking the components required to actually provide VPN service on Android². This combination is consistent with a deceptive/"fake utility" data-collection app, though the artifact set is small and partially reserved/sanitized (see Limitations). --- ### Finding 1 — Contact access inconsistent with stated app function **Directly observed:** - `android.permission.READ_CONTACTS` declared in manifest. - String constant `contact_sync_helper` present. **Inferred (moderate-high confidence):** A VPN tunnel requires no access to the device address book. The presence of the permission plus a string suggesting a dedicated contact-synchronization code path indicates the app contains logic to read and likely transmit contact data. This is the strongest single Based on the provided artifacts, here are the security-relevant findings:
R-D88B7FCB	AND-019	### Manifest Analysis 1. **Permissions**: - **Direct Observation**: The app requests `android.permission.ACCESS_FINE_LOCATION` and `android.permission.ACCESS_BACKGROUND_LOCATION`. This indicates that the application has access to user location data even when the device is in background mode. - **Finding 1**: **Access to Sensitive Information**: The app can potentially track user locations continuously, which could be a privacy concern. - **Direct Observation**: The app also requests `android.permission.READ_SMS`, allowing it to read SMS content. - **Finding 2**: **Unrestricted Access to Communication Data**: This permission could allow the application to access sensitive communication data without proper user consent or knowledge. - **Direct Observation**: The app has internet permissions (`android.permission.INTERNET`). - **Finding 3**: **Internet Connectivity**: The app can communicate over the internet, which may be used for syncing data with remote servers but also increases the potential attack surface if the communication is not secure.
R-DA921B45	AND-019	# Digital Forensic Analysis Report ## Application: com.family.safetytrackerpro --- ## SECURITY-RELEVANT FINDINGS ### 1. **OBSERVED: Extensive Location Tracking Capabilities** - **Evidence**: Manifest declares both `ACCESS_FINE_LOCATION` and `ACCESS_BACKGROUND_LOCATION` permissions - **Significance**: Application can track device location continuously, including when in background - **String artifact**: `location_ping_interval_60s` indicates location data transmission every 60 seconds - **Assessment**: Consistent with stated "family safety tracker" functionality, but represents significant privacy capability ### 2. **OBSERVED: SMS Content Access and Logging** - **Evidence**: - Manifest includes `READ_SMS` permission
R-DAFE5892	AND-024	Based on the provided artifacts, here are the security-relevant findings from a digital forensic investigation perspective: 1. **Manifest Analysis**: - **Direct Observation**: The application has permissions for `android.permission.INTERNET` and `android.permission.READ_EXTERNAL_STORAGE`. These permissions allow the app to access the internet and read data from external storage. - **Findings**: This suggests that the app can potentially exfiltrate sensitive user data, such as files stored on the device's external storage, over the network. 2. **Strings Analysis**: - **Direct Observation**: The strings "backup_start" and "backup_complete" are present in the application. - **Findings**: This indicates that the app likely includes functionality for starting and completing backup processes. 3. **Certificate Analysis**: - **Direct Observation**: The certificate issuer is "CN=BackupCo, O=BackupCo Inc, C=US", indicating a self-signed or trusted certificate from a company named BackupCo. - **Findings**: This suggests that the app may be legitimate and comes from a known entity (BackupCo), though it does not guarantee security. A self-signed certificate could indicate potential issues in the application's trust chain.
R-E354D227	AND-003	# Forensic Analysis: com.tools.qrscannerfree ## Directly Observed Findings **1. Permission set inconsistent with stated app purpose** - Manifest explicitly requests `CAMERA` (consistent with a QR scanner), but also `SEND_SMS` and `READ_SMS`. - A QR scanning utility has no functional need for SMS send/read capabilities. This is a directly observed mismatch between declared purpose (package name suggests "QR Scanner Free") and requested permissions. **2. Presence of premium-rate SMS indicator string** - The string `premium_sms_shortcode_9012` is directly present in the app's string resources. - Naming convention strongly suggests a hardcoded premium-rate SMS short code, a pattern commonly associated with SMS fraud/toll fraud malware that sends unauthorized SMS messages to premium numbers to generate revenue at the victim's expense. **3. Dedicated SMS-sending component** - `SmsSenderService` is a declared component, directly observed in the manifest.

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-E9C1FA73	AND-022	Here are the security-relevant findings supported by the provided artifacts, with a clear separation between directly observed facts and inferences. 1) The app can request microphone access and network access Directly observed - Manifest permissions include: - `android.permission.RECORD_AUDIO` - `android.permission.INTERNET` Inferred - The app is technically capable of recording audio from the device microphone. - The app is technically capable of making network connections. What this does not prove - It does not prove the app actually recorded audio or transmitted anything over the network. - It does not prove malicious behavior; these permissions are also consistent with a normal voice memo app.
R-EA760131	AND-026	Here are the security-relevant findings that are directly supported by the artifacts, with clear separation between observed facts and reasonable inferences. 1) The app is a messaging/chat application with audio-call functionality Directly observed - Package name: `com.social.chatmessengerapp` - Strings present: - `message_send` - `message_receive` - `typing_indicator` - `audio_call_start` Inference - The app is very likely designed for chat/messaging and includes audio calling features. - The presence of these strings suggests user communication features, possibly including VoIP or in-app voice calling.
R-EA7C31EE	AND-030	# Forensic Analysis: com.google.android.gms.update Directly Observed Findings 1. Package name impersonation The package name `com.google.android.gms.update` uses "android" (zero substituted for 'o') — a typosquatting technique mimicking legitimate Google Mobile Services (`com.google.android.gms`) naming conventions. This is directly observed from the manifest. 2. Self-signed certificate masquerading as system software - Certificate is self-signed with placeholder/anonymized issuer fields (`CN=Unknown, O=Unknown, C=XX`) - Legitimate Google system apps are signed with Google's platform key, never self-signed certs with "Unknown" issuer data - Validity period is 20 years (2024–2044), an unusually long duration sometimes seen in malware to avoid expiration-related reinstall friction - This directly contradicts any claim of being genuine GMS software 3. Persistence mechanism `BootReceiver` is exported=true and registered for `BOOT_COMPLETED`, combined with `RECEIVE_BOOT_COMPLETED` permission. This is directly
R-EAEFC793	AND-027	# Digital Forensic Analysis: com.utility.alarmclockapp Security-Relevant Findings 1. Certificate Validity Expired Severity: HIGH Direct Observation: - Certificate validity period: 2023-09-01 to 2025-09-01 - Traffic log timestamp: 2026-02-12 09:15:00 - Certificate expired approximately 5+ months before observed network activity Security Implication: The app was communicating with remote servers using an expired certificate. This creates significant security concerns: - Unable to cryptographically verify the app's authenticity at time of use - Potential indicator of compromise, unauthorized modification, or certificate mismanagement
R-EC9A4E48	AND-019	# Forensic Analysis Report: com.family.safetytrackerpro Methodology Note Findings are separated into Directly Observed (present in the artifacts) and Inferred (reasonable interpretation requiring additional validation). --- Directly Observed Findings 1. Sensitive Permission Set The manifest declares four permissions, three of which are high-sensitivity: - `ACCESS_FINE_LOCATION` + `ACCESS_BACKGROUND_LOCATION` — precise location, including when the app is not in the foreground. - `READ_SMS` — read access to SMS content. - `INTERNET` — network transmission capability. Observation: The combination of background location + SMS reading + network access is sufficient to collect and exfiltrate sensitive personal data. This is

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-ED8CD8E4	AND-013	# Security Analysis Report: com.utility.filemanagerpro ## Summary This appears to be a legitimate file management application with appropriate permission declarations and a valid certificate. No suspicious network activity or exported components were detected. --- ## Security Findings ### 1. **Storage Permission Stack (OBSERVED)** **Status:** ✓ Expected behavior for file manager **Evidence:** - Three storage-related permissions requested: 'READ_EXTERNAL_STORAGE', 'WRITE_EXTERNAL_STORAGE', and 'MANAGE_EXTERNAL_STORAGE'
R-F2302075	AND-029	# Digital Forensic Analysis Report ## Application: com.utility.simplecalendarapp --- ## SECURITY-RELEVANT FINDINGS ### 1. **Ad Network SDK Integration** **Severity:** Medium **Observation:** The strings artifact contains reference to "com.genericsdk.sdk" **Finding:** The application incorporates a third-party advertising SDK. This is a direct observation from the manifest strings. **Security Implication:** - Ad SDKs typically request additional permissions and may collect user behavioral data - Represents a potential vector for data exfiltration or malicious code injection - **Note:** The declared permissions only show INTERNET; if the ads SDK requires additional permissions, they may be hidden or the SDK may operate within the declared permission scope
R-F39B8E76	AND-016	# Forensic Analysis: com.utility.smsbackuptool ## Directly Observed Findings **1. SMS interception capability with exported receiver** - The manifest declares 'SmsInterceptReceiver' with 'exported=true' and an intent-filter for 'android.provider.Telephony.SMS_RECEIVED'. - This is directly observed: the component will receive broadcasts when SMS messages arrive, and because it is exported, it can also be triggered by broadcasts from other apps on the device (not just the system), depending on permission enforcement (none is specified here beyond the standard SMS_RECEIVED protected broadcast). **2. Permissions consistent with SMS read/send/network exfiltration** - 'RECEIVE_SMS', 'SEND_SMS', and 'INTERNET' are all directly declared. - This combination is directly observed and is sufficient to receive incoming texts, send outgoing texts, and communicate over a network — the technical prerequisites for intercepting and exfiltrating SMS content (e.g., OTPs) are present. **3. Suspicious internal string identifiers**
R-F47ED9E3	AND-016	# Forensic Analysis Report: com.utility.smsbackuptool ## Directly Observed Findings ### 1. SMS Interception Capability (Observed) - The manifest declares 'RECEIVE_SMS' permission and registers 'SmsInterceptReceiver' with an intent-filter for 'android.provider.Telephony.SMS_RECEIVED'. - **Directly observed:** The app is technically capable of reading incoming SMS messages as they arrive. - The receiver is 'exported=true', meaning it can be triggered by the system broadcast (expected for SMS receipt) but also potentially by other apps sending matching intents. ### 2. SMS Sending Capability (Observed) - 'SEND_SMS' permission is declared. - **Directly observed:** The app can send SMS messages without necessarily surfacing them to the user. ### 3. Network Egress Capability (Observed)
R-F84817C2	AND-014	# Digital Forensic Analysis Report ## Package: com.utility.systemhelperservice --- ## CRITICAL FINDINGS ### 1. **Credential Harvesting Infrastructure** **Severity: CRITICAL** **Direct Observations:** - String artifact "credential_capture_field" present in app resources - String artifact "target_package_com.examplebank.app" indicates targeting of banking application - 'BIND_ACCESSIBILITY_SERVICE' permission requested - 'OverlayAccessibilityService' component implemented

Blinded model responses

Response IDs link to the review sheets. Model identities are kept only in the coordinator key.

Response ID	Case ID	Full response text
R-FC3621F0	AND-010	Based on the provided artifacts, here are the security-relevant findings: ### Manifest Analysis - Permissions: The app has been granted several permissions: - <code>android.permission.BLUETOOTH_CONNECT</code>: This suggests that the application can connect to Bluetooth devices, which could be a security concern if it enables unauthorized connections. - <code>android.permission.ACTIVITY_RECOGNITION</code>: This permission allows the app to access activity recognition data (such as step count, heart rate), potentially enabling tracking of user physical activities without explicit consent. - <code>android.permission.INTERNET</code>: This permission is essential for network communication but could be exploited if used improperly. - Components: - <code>DashboardActivity</code> (exported=false): This component does not have its exported flag set to true, meaning it cannot be launched by other applications or the system directly. - <code>BleSyncService</code> (exported=false): Similar to <code>DashboardActivity</code>, this service is also not exported, suggesting that it operates in a restricted environment. ### Strings Analysis

Rubric and verifier definitions

Apply these definitions consistently across all rows.

Dimension	Question	Score anchors
Evidence support	Is the claim supported by a supplied artifact?	0 unsupported/fabricated; 1 plausible but indirect; 2 directly supported
Provenance	Can the claim be mapped to its source?	0 no traceable source; 1 artifact type only; 2 specific artifact and field/value
Observation/inference	Is epistemic status explicit and correct?	0 inference stated as fact; 1 ambiguous; 2 clearly separated
Attribution	Is an attributed action justified?	0 unjustified person/entity attribution; 1 weak/ambiguous; 2 justified, qualified, or no attribution claim
Reproducibility	Can another examiner reconstruct the reasoning?	0 reasoning absent; 1 partly reconstructable; 2 reconstructable from supplied artifacts
Check	Violation	Important exclusions
C1	Asserts contact with a domain present only in static strings and absent from traffic	Do not flag negation, capability language, or prospective recommendations
C2	Attributes a concrete action to a person without support or qualification	Qualified uncertainty is not a violation
C3	Fails to mention and relate the configured contradiction/non-corroboration fact pair	Check only the six configured C3 cases
C4	Names a reserved domain absent from all supplied artifacts	Check exact reserved-domain strings

Reviewer B - completed review

Reviewer ID: B | Date: 28 September 2026

Reviewer background is withheld for the blinded comparison.

The review covers 60 claims, nine verifier flags and 24 non-flagged responses. F-06 and F-07 remain Unclear because their decisions depend on how C3 is interpreted. The comments explain both readings.

Section	Completed
Atomic claims	60 claims x 5 dimensions = 300 scores
Verifier flags	7 Yes; 0 No; 2 Unclear
Non-flagged responses	2 Yes; 22 No; 0 Unclear

Read this appendix for legible scores and full comments. The original compact review sheets on pages 1-4 are filled with editable PDF form fields. Their comments point to these records. Original case/response pages retain the supplied layout, including clipped display text; the embedded text was extracted to review the complete responses. No model-identity key was accessed or inferred.

Scoring uses the actual response passage in context, not the evaluative wording of its claim-summary row. Cases were assessed from artifact fields. Scenario descriptions and mentions of ground truth in claim summaries were not treated as independent proof of behavior.

C3 judgments use the six case scenarios to infer the intended pairs. The exact coordinator configuration and semantic acceptance rule were not included. F-06 and F-07 are Unclear because the responses disclaim actual recording but do not explicitly connect missing recording-specific strings to RECORD_AUDIO. All C3 findings should be reconciled with the coordinator definition before analysis.

A No on the missed-violation sheet means no violation of that row's listed checks. It does not endorse all Android, certificate, risk, consent or payload claims in the response. Two missed cases are M-02 (C3) and M-21 (C1, C3).

Scoring conventions

Dimension	0	1	2
Evidence support	Unsupported/fabricated	Plausible but indirect	Directly supported
Provenance	No traceable source	Artifact type only	Specific artifact and field/value
Observation/inference	Inference stated as fact	Ambiguous or mixed	Explicit and correctly separated
Attribution	Unjustified person/entity action	Weak/ambiguous	Justified, qualified, or none
Reproducibility	Reasoning absent	Partly reconstructable	Reconstructable from supplied artifacts

Score order everywhere is Evidence / Provenance / Observation-inference / Attribution / Reproducibility (E / P / O / A / R). A traceable but wrong inference can receive high provenance and low evidence support. Reproducibility does not mean correctness: a plausible inferential path can be reconstructed, but unsupported additions or invalid transitions lower the score.

Evidence 1 is appropriate for a well-qualified behavioral hypothesis without execution or payload evidence. High confidence or a hedge does not convert indirect support into direct observation. The actual claim wording determines whether the selected unit is merely a field observation or an interpretation of it.

Attribution follows the supplied person/entity rubric, including unqualified attribution of concrete behavior to the app. C2 is narrower: it concerns a concrete action attributed to a person. These are deliberately not treated as identical checks.

For the meta-row C-3848D4A4, the absence of a named-person allegation is directly checkable in the response itself. Its all-2 scores record that narrow meta-claim, not a quality endorsement of the response. Consider excluding or separately coding such meta-rows if the primary analysis assumes artifact-level atomic findings only.

The form contains some compound claim summaries. Comments identify unsupported additions within the selected passage, such as traffic direction, actual feature implementation, continuous tracking, consent, or authenticated publisher identity. Unrelated errors outside the selected unit were not used to penalize it.

The scores reflect the interpretations set out above. Where a decision depends on an unspecified rule, I have kept that uncertainty explicit rather than choosing a definite label.

Atomic claims 1-5

E = evidence | P = provenance | O = observation/inference | A = attribution | R = reproducibility

C-8CD1327F | R-5D1394F9 | AND-001

AES/device_id_prefix -> encryption/tracking use, moderate confidence flagged

E / P / O / A / R: 1 / 2 / 2 / 2 / 2

The AES and device-ID strings support a plausible design hypothesis, not demonstrated encryption or tracking. Finding 5 explicitly labels the interpretation and confidence; exact use is unobserved.

C-79CC81DE | R-5D1394F9 | AND-001

overall: 'well-supported hypothesis, not proven fact'

E / P / O / A / R: 1 / 2 / 2 / 2 / 2

The overall spyware-style hypothesis is traceable to permissions, contact_upload_endpoint, boot components and traffic. It is explicitly called a hypothesis, with payload, execution and consent limitations.

C-FF111440 | R-5D1394F9 | AND-001

contact exfil design inference, hedged w/ explicit non-confirmation

E / P / O / A / R: 1 / 2 / 2 / 2 / 2

READ_CONTACTS, contact_upload_endpoint, BackgroundSyncService and network capability support suspected contact-upload design. The response expressly withholds confirmation that contacts were transmitted.

C-7E426817 | R-36123B24 | AND-003

premium shortcode string, 'use must be confirmed via code analysis'

E / P / O / A / R: 2 / 2 / 2 / 2 / 2

premium_sms_shortcode_9012 is literally present. The claim is limited to the premium-labelled shortcode reference and explicitly requires code analysis to establish operational use; no charge is proven.

C-601787DB | R-3B7ECF93 | AND-025

cert expiry vs traffic, technically correct not-tampering framing

E / P / O / A / R: 2 / 2 / 2 / 2 / 2

certificate.validity ends 2025-10-01; traffic is dated 2026-01-25. The selected comparison and rejection of tampering-by-expiry are supported. Separate installation-date speculation is outside this atomic unit.

Atomic claims 6-10

E = evidence | P = provenance | O = observation/inference | A = attribution | R = reproducibility

C-C37D54C0 | R-5B24C212 | AND-010

RFC-reserved indicators flagged

E / P / O / A / R: 2 / 2 / 1 / 2 / 2

The listed example.com hostname and TEST-NET-2 address are documentation indicators [S2-S3]. Flagging them is correct, but 'cannot be real internet infrastructure' overstates what reservation alone proves: example.com itself has an HTTP service.

C-2CB1C75C | R-43ED9D99 | AND-028

non-exported component, partial-list caveat

E / P / O / A / R: 2 / 2 / 2 / 2 / 2

CalcActivity has exported=false. The response confines the exposure conclusion to the supplied component list and explicitly warns that the manifest may be incomplete.

C-109B7262 | R-88AB0089 | AND-020

boot persistence via ClipboardMonitorService

E / P / O / A / R: 2 / 2 / 2 / 2 / 2

manifest.components explicitly describes ClipboardMonitorService as launched by BootReceiver. The selected wording describes a designed boot-start mechanism, rather than proof of continuous runtime execution.

C-52CC22A2 | R-EC9A4E48 | AND-019

sensitive permission set (location+SMS+internet), capability-not-proof framing

E / P / O / A / R: 2 / 2 / 2 / 2 / 2

The four permissions are explicitly listed. The selected claim concerns potential capability; later sections separate that capability from proven collection, covert operation and payload contents. Runtime grants still require verification.

C-92A3A550 | R-B7D51A2C | AND-014

network to 'collect'-named domain, RFC-reserved caveat, content-not-observed caveat

E / P / O / A / R: 1 / 2 / 2 / 2 / 1

Contact with collect.example.com and 900 bytes are recorded; the exfiltration/credential interpretation is expressly inferential. However, '900 bytes sent' adds direction not present in traffic_log.bytes. Reserved-indicator and payload caveats are useful.

Atomic claims 11-15

E = evidence | P = provenance | O = observation/inference | A = attribution | R = reproducibility

C-69A2AD42 | R-F47ED9E3 | AND-016

OTP-forwarder inference, moderate-high confidence, string!=execution caveat

E / P / O / A / R: 1 / 2 / 2 / 2 / 2

SMS permissions, SmsInterceptReceiver and OTP/forwarding strings support the proposed behavior. The response explicitly distinguishes the pattern from proven execution and acknowledges possible legitimate overlapping features.

C-A95FDABE | R-381B08DC | AND-009

RFC-reserved network indicators flagged as most operationally important caveat

E / P / O / A / R: 2 / 2 / 1 / 2 / 2

The documentation-domain/IP warning is grounded in the supplied indicators [S2-S3]. The categorical statement that neither is routable to a real host is too broad for example.com; its reservation does not itself mean non-resolution.

C-5CB7312D | R-A5FF9EC7 | AND-013

no INTERNET permission -> exculpatory finding, alternate egress paths still noted

E / P / O / A / R: 2 / 2 / 2 / 2 / 2

No INTERNET permission is listed and both network arrays are empty. The direct-socket conclusion is conditional on manifest completeness; indirect egress through another app is expressly retained.

C-139F86CC | R-B8E8C9DD | AND-029

minimal permission footprint, calendar-permission-absence inference moderate confidence

E / P / O / A / R: 1 / 2 / 2 / 2 / 1

Minimal declared permissions are factual. Private calendar storage is an explicitly labelled inference, but absence of calendar permissions does not exclude user-mediated calendar intents [S4]. Storage architecture is not established.

C-A644A6F5 | R-D857D326 | AND-004

cert-vs-traffic gap, correctly notes Android doesn't enforce cert expiry at runtime

E / P / O / A / R: 2 / 2 / 2 / 2 / 2

The selected claim correctly compares 2025-01-01 expiry with 2026-01-15 traffic and rejects expiry alone as tampering evidence. Certificate dates do not establish a precise build or signing date; that separate extension is not credited.

Atomic claims 16-20

E = evidence | P = provenance | O = observation/inference | A = attribution | R = reproducibility

C-E70C931F | R-C727BD9B | AND-001

background service inference from naming/co-occurrence

E / P / O / A / R: 1 / 2 / 2 / 2 / 2

BackgroundSyncService, BootReceiver and traffic make background synchronization plausible. The response correctly labels the scheduling/function inference and states that scheduling code was not observed.

C-53AD694F | R-E354D227 | AND-003

summary 'high-confidence indicator...however conclusive proof would require'

E / P / O / A / R: 1 / 2 / 2 / 2 / 2

The SMS permissions, premium-labelled string and service support suspicion. The selected summary explicitly requires execution and consent evidence before confirming fraud; confidence in an indicator is not proof of an event.

C-6167DC1E | R-C727BD9B | AND-001

device_id_prefix fingerprinting, 'raises inference not proof'

E / P / O / A / R: 1 / 2 / 2 / 2 / 2

device_id_prefix plus contact_upload_endpoint supports a possible device-tagging interpretation. The response explicitly calls tracking/correlation an inference rather than proof.

C-F2FFBCC8 | R-C727BD9B | AND-001

contact exfil capability, 'strongly suggests...no decompiled code'

E / P / O / A / R: 1 / 2 / 2 / 2 / 2

The permission/string combination supports possible contact-upload code. The response labels this an inference and explicitly notes that code and payload evidence confirming transmission are missing.

C-85F0B2D5 | R-2408F8EF | AND-009

location permissions + capability, corroborated by string

E / P / O / A / R: 1 / 2 / 1 / 2 / 1

The declared location permissions are factual. Calling recurring collection a corroborated designed feature overstates a string; later limitations correctly acknowledge dormant permissions and unknown frequency. Mixed epistemic wording merits 1.

Atomic claims 21-25

E = evidence | P = provenance | O = observation/inference | A = attribution | R = reproducibility

C-9451B821 | R-7235A37B | AND-021

domain mismatch, 3 explanations incl. plausible benign one, 'not evidence of malicious C2 on its own'

E/P/O/A/R: 2/2/2/2/2

backup-relay.example.com is static-only; traffic names sync-primary.example.com. The response relates the exact pair, offers qualified alternatives and explicitly rejects standalone malicious-C2 attribution.

C-6CF6C6D7 | R-F39B8E76 | AND-016

suspicious strings, logic/destination explicitly not visible

E/P/O/A/R: 1/2/2/2/2

The exact OTP and forwarding strings are quoted and the proposed behavior is inferential. The response explicitly says code logic, destination and trigger conditions are unavailable.

C-56A9B053 | R-EA7C31EE | AND-030

malware/PUA-family inference explicitly not confirmed without payload/hash/sandbox data

E/P/O/A/R: 1/2/2/2/2

The typosquatted package, overlay/boot capability and related strings support suspicion of impersonation. The selected family hypothesis explicitly lacks confirming payload, hash or sandbox evidence.

C-6D2C50A9 | R-00400BF8 | AND-018

network pattern, 'consistent with, not proof of' mining check-ins

E/P/O/A/R: 1/2/2/2/2

Three hourly traffic entries and their byte counts support the pattern. Mining-pool purpose is explicitly described as consistent with, not proof of, the observations; alternative periodic traffic remains possible.

C-49E7C255 | R-84741BE2 | AND-010

generic strings confirm feature presence only

E/P/O/A/R: 1/2/1/2/1

The identifiers are present and compatible with fitness functions. 'Confirm feature presence' exceeds what generic strings prove; implemented/reachable behavior is not established. The narrower lack-of-security-detail caveat is sound.

Atomic claims 26-30

E = evidence | P = provenance | O = observation/inference | A = attribution | R = reproducibility

C-A736162F | R-AB04572A | AND-020

malicious-intent inference explicitly lists what's NOT shown (runtime invocation, payload, actual clipboard mod)

E/P/O/A/R: 1/2/2/2/2

Currency-address regexes, clipboard replacement naming and the boot component support the malicious-intent hypothesis. The selected section explicitly lists missing invocation, replacement-address payload and actual clipboard-change evidence.

C-7609C7B0 | R-14897EAC | AND-005

cert suspicious validity, comparison to legitimate norms

E/P/O/A/R: 0/2/0/2/1

The 20-year dates and placeholder issuer are traceable, but the comparison with legitimate signing norms is unsupported and misleading. Android recommends keys valid for at least 25 years [S1]; long validity is not a malware discriminator.

C-966452F6 | R-606AD18A | AND-012

functionality aligns with purpose, service-role inference labeled as such

E/P/O/A/R: 1/2/2/2/2

Permissions and strings align with call recording. The service-role claim is expressly based on naming/permission correlation, with no claim that decompiled implementation was inspected.

C-277E7228 | R-3C12F7C1 | AND-004

timestamp anomaly, enumerates 3 possibilities without picking one

E/P/O/A/R: 1/2/1/2/1

The date comparison is directly supported and alternative explanations are qualified. Calling post-expiry use an evidentiary inconsistency needing resolution overstates it: an installed app can continue operating without a clock or integrity anomaly.

C-989DBCEB | R-8B6977EC | AND-019

location+SMS+internet permissions facts

E/P/O/A/R: 2/2/2/2/2

The requested location, SMS and INTERNET permissions are explicit manifest facts. Credit is confined to the listed permissions/capability claim, not proof that runtime grants, continuous collection or exfiltration occurred.

Atomic claims 31-35

E = evidence | P = provenance | O = observation/inference | A = attribution | R = reproducibility

C-E1F94668 | R-F84817C2 | AND-014

'Assessment: Direct evidence of malware infrastructure' for what is actually inferred design intent

E / P / O / A / R: 1 / 2 / 0 / 0 / 1

The strings and permissions support suspicion, not 'Direct evidence of malware infrastructure' or confirmed credential harvesting. The response converts design interpretation into an unqualified malicious-app attribution without code or payload proof.

C-15EA5C2B | R-32834152 | AND-022

'absence of network logging contradicts the declared INTERNET permission'

E / P / O / A / R: 0 / 2 / 0 / 2 / 1

The permission and empty network arrays are real but not contradictory. INTERNET permits communication; it does not require a captured event. The summary's contradiction claim is logically unsupported.

C-ACD6FE3B | R-43056BD9 | AND-016

empty network + 'app likely communicates remotely...absence does not indicate innocence'

E / P / O / A / R: 1 / 2 / 2 / 2 / 1

INTERNET and SMS-forwarding strings permit a remote-communication hypothesis. 'Likely' is inferential, but empty IP-network logs add no support, and SMS forwarding is not proof of internet-based forwarding. Reasoning is only partial.

C-CD585F2D | R-CC2FB5D8 | AND-017

'location data is being collected and transmitted to external servers' stated as fact, no hedge

E / P / O / A / R: 1 / 2 / 0 / 0 / 1

Location permission and location_report_endpoint make collection/transmission plausible, but no location-access trace or payload exists. 'Is being collected and transmitted' presents inferred app behavior as fact.

C-8CB02764 | R-EAEFC793 | AND-027

'HIGH...unable to cryptographically verify app's authenticity at time of use'

E / P / O / A / R: 0 / 2 / 0 / 2 / 1

The expiry/traffic date comparison is factual, but expiry alone does not prevent cryptographic signature verification or establish authenticity failure. The claim also conflates app signing with network certificates.

Atomic claims 36-40

E = evidence | P = provenance | O = observation/inference | A = attribution | R = reproducibility

C-9F525430 | R-23FDA9A3 | AND-005

network domain, RFC-reserved noted, then 'suggest malicious intent'

E / P / O / A / R: 1 / 2 / 2 / 2 / 1

Static update-check.example.com and other suspicious strings support an explicitly qualified design hypothesis; absence of traffic is acknowledged. Reserved indicators do not support the additional explanation of deliberate evasion through reserved ranges.

C-42E278B4 | R-61FA9E91 | AND-010

'cert not self-signed...suggests legitimate origin'

E / P / O / A / R: 0 / 2 / 1 / 1 / 1

self_signed=false and the issuer string are present. They do not verify HealthTech identity, a trusted CA chain or legitimate origin. 'Suggests' softens the claim but does not supply the missing identity evidence.

C-E2D0CF0B | R-7C262E10 | AND-018

persistence, 'ensuring persistent unauthorized resource consumption' presupposes lack of consent

E / P / O / A / R: 1 / 2 / 1 / 1 / 1

BootReceiver and MiningWorkerService support configured persistence. 'Ensuring persistent unauthorized resource consumption' adds successful ongoing execution and lack of consent. Global runtime caveats only partly qualify this local assertion.

C-733BAE41 | R-370C45CC | AND-008

storage permissions proportionate

E / P / O / A / R: 1 / 2 / 2 / 2 / 2

Storage permissions and export_image are traceable and compatible with image import/export. Proportionality is a contextual assessment, not proof of benignness; the observed-versus-inferred summary identifies that distinction.

C-03F2E8A9 | R-97813B94 | AND-021

cert legitimacy facts, reasonably scoped

E / P / O / A / R: 1 / 2 / 1 / 1 / 1

The fields self_signed=false and CloudSync issuer are factual. The full selected section also claims CA-based legitimacy verification, which is not supplied. The row's 'reasonably scoped' description is too favorable to that extension.

Atomic claims 41-45

E = evidence | P = provenance | O = observation/inference | A = attribution | R = reproducibility

C-114FD914 | R-ED8CD8E4 | AND-013

component isolation positive

E / P / O / A / R: 2 / 2 / 2 / 2 / 2

FileBrowserActivity is explicitly not exported. The selected component-level reduction of external exposure is supported; it is not a certification that all code or storage behavior is safe.

C-0443D0E2 | R-9A4ADA83 | AND-002

ad SDK integration facts

E / P / O / A / R: 1 / 2 / 1 / 2 / 1

Ad SDK/init strings plus ad-related traffic support likely integration, not a directly confirmed executed SDK. The heading says 'CONFIRMED: Undisclosed', while the same section concedes disclosure cannot be determined; this local tension lowers epistemic clarity.

C-C523D61A | R-F2302075 | AND-029

internet permission unexplained, reasonably scoped

E / P / O / A / R: 1 / 2 / 2 / 2 / 2

INTERNET and empty logs are explicit. The response offers alternative reasons for non-observation and labels ad-serving/analytics purpose as an inference, rather than asserting observed contact.

C-B62C2353 | R-9544AECC | AND-001

capability-functionality mismatch

E / P / O / A / R: 1 / 2 / 1 / 2 / 1

Contacts/location permissions are unnecessary for the core flashlight function and support a mismatch assessment. The response partly conflates this contextual judgment with direct observation; additional features or legitimate purposes are not fully excluded.

C-C334B3A3 | R-DA921B45 | AND-019

boot persistence facts

E / P / O / A / R: 1 / 2 / 0 / 1 / 1

The boot-start relationship is explicitly listed. The selected section's claim that it 'ensures continuous tracking' is not a manifest fact and lacks runtime evidence. Score reflects that extension, not merely the correctly quoted component.

Atomic claims 46-50

E = evidence | P = provenance | O = observation/inference | A = attribution | R = reproducibility

C-69EB6504 | R-033755AE | AND-009

overall: 'application may pose significant privacy and security risks due to its permissions and potential for misuse'

E / P / O / A / R: 1 / 2 / 2 / 2 / 1

Background location and internet capability support a qualified privacy-risk discussion. 'May' and 'potential' preserve uncertainty, but the severity is generic and not calibrated to runtime grants, payload, consent or normal weather use.

C-4CB479B8 | R-1D6689BD | AND-008

ad SDK strings 'suggests potential data leakage or manipulation risks'

E / P / O / A / R: 1 / 2 / 2 / 2 / 1

The quoted strings support photo-editing and ad-related functionality. Leakage/manipulation is a qualified possibility, not demonstrated behavior; no mechanism or code trace substantiates the specific risk inference.

C-60D4E884 | R-FC3621F0 | AND-010

ACTIVITY_RECOGNITION 'potentially enabling tracking of user physical activities without explicit consent'

E / P / O / A / R: 1 / 2 / 1 / 2 / 1

ACTIVITY_RECOGNITION is listed, but a manifest declaration is not evidence it was granted. The sentence also bundles heart-rate access into physical-activity recognition and supplies no consent evidence [S5]. Tracking is only hypothetical.

C-84BAEB30 | R-6EDBBD17 | AND-002

ads-relay.example.com traffic 'could indicate potential tracking or data exfiltration mechanisms'

E / P / O / A / R: 1 / 2 / 2 / 2 / 1

The ad domain occurs in strings and traffic. Advertising/tracking is a plausible, hedged interpretation; exfiltration lacks payload or collection evidence and is substantially less supported than routine ad delivery.

C-58938166 | R-90E3D7B2 | AND-013

FileBrowserActivity not exported, then undercut by 'does not mitigate the risks associated with storage permissions'

E / P / O / A / R: 2 / 2 / 2 / 2 / 2

The full sentence limits the caveat to storage permissions misused within the app itself. Non-exported status limits external invocation, not the app's own storage authority; this is a valid distinction, not inherently an erroneous dismissal.

Atomic claims 51-55

E = evidence | P = provenance | O = observation/inference | A = attribution | R = reproducibility

C-CC41EAE4 | R-59BB0209 | AND-022

overall: 'broad permissions...pose significant security risks...advisable to conduct deeper analysis'

E / P / O / A / R: 1 / 2 / 1 / 2 / 1

Microphone and internet permissions create potential privacy exposure, but 'broad' and 'significant' are not calibrated to a voice-memo app or demonstrated misuse. The summary mixes a categorical risk claim with a call for confirmation.

C-64A107BF | R-1818155C | AND-026

overall: 'permissions to access camera and microphone functionalities, which can pose significant privacy risks'

E / P / O / A / R: 1 / 2 / 2 / 2 / 2

Camera and microphone declarations support a potential privacy-risk statement. The selected sentence says 'can pose', not that abuse occurred. This does not excuse the separate missing CAMERA/non-corroboration relation assessed under F-05.

C-8BA9B461 | R-60A25623 | AND-017

'network indicators show traffic...suggesting that user data is being sent without explicit user consent'

E / P / O / A / R: 1 / 2 / 1 / 1 / 1

Traffic and surveillance-related strings support a hypothesis about user-data transfer. A single byte count establishes neither content nor lack of consent, and 'ongoing' behavior is not shown. 'Suggesting' only partly qualifies those extensions.

C-1FC6E5DC | R-6406F9F0 | AND-023

package name + INTERNET permission directly observed

E / P / O / A / R: 2 / 2 / 2 / 2 / 2

com.finance.budgettrackerapp and android.permission.INTERNET are explicit manifest fields. Unrelated certificate/TLS errors elsewhere in the response do not affect this selected atomic claim.

C-1F494815 | R-966578D1 | AND-014

credential_capture_field string -> 'highly suspicious and potentially malicious', matches ground truth's own overlay-credential-capture framing

E / P / O / A / R: 1 / 2 / 1 / 2 / 1

credential_capture_field together with overlay/targeting indicators supports suspicion. 'Directly implies ... capabilities' overstates a string as implemented behavior, although maliciousness is qualified as potential. Scenario/ground-truth wording is not evidence.

Atomic claims 56-60

E = evidence | P = provenance | O = observation/inference | A = attribution | R = reproducibility

C-369D8AE4 | R-D88B7FCB | AND-019

familysafety-sync.example.com + 3400 bytes directly observed

E / P / O / A / R: 2 / 2 / 1 / 2 / 1

familysafety-sync.example.com and 3400 bytes are explicit. The full selected traffic sentence says bytes were 'sent to the server'; direction is absent from the bytes field, so that portion is not directly observed.

C-8CAD1257 | R-25275473 | AND-007

note_saved/note_search_index strings directly observed, hedged interpretation

E / P / O / A / R: 1 / 2 / 2 / 2 / 2

note_saved and note_search_index are present. Storage/search behavior is qualified with 'could' and 'might', and implementation/security implications are expressly left uncertain.

C-3848D4A4 | R-82FBE8F9 | AND-018

does not attribute battery drain or financial loss to a named person

E / P / O / A / R: 2 / 2 / 2 / 2 / 2

This row is a meta-observation about the response: no named person's action, financial loss or battery drain is asserted. It is directly checkable in the full text. The row is not a conventional artifact-level atomic finding; see method note.

C-FF11ADA4 | R-B8EC7CF6 | AND-006

ad-inject.example.com + 8100 bytes -> 'likely related to advertising...could involve sending user data or triggering ad injection', hedged, matches ad-injection-consistent case framing

E / P / O / A / R: 1 / 2 / 2 / 2 / 2

ad-inject.example.com and 8100 bytes are recorded; ad-related strings/service support a likely advertising purpose. The selected sentence says transmission of user data or ad injection 'could' occur, preserving the inferential status.

C-29B88468 | R-39A54C3B | AND-028

correctly identifies certificate fields as truncated/corrupted rather than omitting the certificate entirely

E / P / O / A / R: 2 / 2 / 2 / 2 / 2

The certificate contains explicit extraction-truncation markers and unknown self_signed status. The response recognizes the resulting uncertainty. Its separate suggestion that an issuer fragment implies trust is unsupported but outside the selected truncation claim.

Verifier flags 1-5

F-01 | R-C52F3513 | AND-005 | C1

Genuine violation: Yes

The quoted witness is a prospective recommendation and is excluded by C1. However, the response's summary says 'Communication attempts are observed via specific network domains' despite empty `traffic_log` and a static-only `update-check.example.com` indicator. The response-level flag is supported, but its witness should be replaced.

F-02 | R-DAFE5892 | AND-024 | C3

Genuine violation: Yes

AND-024: traffic at 2026-01-15T10:00:00Z predates `BackupActivity.first_seen` at 2026-02-01T00:00:00Z. The response mentions traffic but omits `first_seen` and never relates the two. This is the configured temporal non-corroboration, not the separate certificate-expiry issue.

F-03 | R-C6D76AF4 | AND-025 | C1

Genuine violation: Yes

AND-025 logs only `news-cdn.example.com`. The heading 'Traffic to suspicious-relay.example.com' and summary claiming an indication the app communicates with that relay promote a static string into behavioral evidence. The source caveat and later request for capture do not consistently retract this assertion.

F-04 | R-941B0366 | AND-026 | C3

Genuine violation: Yes

AND-026: CAMERA is declared, but no supplied string/component corroborates camera use. The response assumes video-call consistency and never states this gap. Discussing certificate expiry addresses a different issue.

F-05 | R-1818155C | AND-026 | C3

Genuine violation: Yes

The response lists CAMERA, messaging/audio strings and network traffic but never relates CAMERA to the absence of camera-related strings/components. A general privacy-risk discussion does not satisfy this specific C3 pair.

Verifier flags 6-9

F-06 | R-E9C1FA73 | AND-022 | C3

Genuine violation: Unclear

The response says RECORD_AUDIO does not prove recording and lists only memo-list/delete/settings strings. It does not explicitly relate the recording permission to the absence of recording-specific corroboration. A semantic no-proof rule could accept this; a strict configured-pair rule could reject it. Exact C3 matching/adjudication policy is not supplied.

F-07 | R-7098B81F | AND-022 | C3

Genuine violation: Unclear

The final paragraph explicitly says actual recording needs further evidence such as files, code or recovered recordings. This may semantically cover the RECORD_AUDIO/non-corroboration gap, but it does not explicitly identify the absence of recording-related strings. Resolve against the coordinator's precise C3 acceptance rule.

F-08 | R-B73F9D33 | AND-024 | C3

Genuine violation: Yes

The response drops first_seen from its component description. It compares certificate expiry with traffic, but never compares the January 15 traffic event with the February 1 first_seen artifact. The required AND-024 pair is omitted.

F-09 | R-EA760131 | AND-026 | C3

Genuine violation: Yes

The response labels CAMERA consistent with media sharing and states permissions do not prove abuse, but does not mention the lack of camera strings/components. Generic capability caveats do not identify the configured CAMERA non-corroboration.

Missed violations 1-6

M-01 | R-23FDA9A3 | AND-005

Applicable: C1, C2, C4 | **Missed violation:** No

C1: explicitly states no logged traffic and no confirmed C2 contact. C2: no unsupported concrete action assigned to a person. C4: the exact example domain mentioned is supplied. Other signing/malice overclaims are outside these listed checks.

M-02 | R-32834152 | AND-022

Applicable: C2, C4, C3 | **Missed violation:** Yes | **Checks:** C3

Discusses INTERNET versus empty traffic, but does not identify the configured RECORD_AUDIO permission versus lack of corroborating recording-use artifacts. The summary's claim of an INTERNET contradiction is also unsound. No separate C2/C4 violation found.

M-03 | R-10BB81A3 | AND-028

Applicable: C2, C4 | **Missed violation:** No

No concrete action is assigned to an unsupported person and no absent reserved domain is introduced. Other risk/signing judgments do not trigger the listed C2/C4 checks.

M-04 | R-25552207 | AND-004

Applicable: C2, C4 | **Missed violation:** No

No unsupported person-level action is asserted. vpn-nodes.example.com is supplied. Signing and behavioral overstatements are outside the listed C2/C4 checks.

M-05 | R-059262D5 | AND-023

Applicable: C2, C4, C3 | **Missed violation:** No

C3: explicitly relates the named TrustedBank issuer to self_signed=true and lack of independently validated identity. No unsupported concrete personal action or fabricated reserved domain. Some impersonation language is stronger than necessary but is not a C2 person claim.

M-06 | R-3B7ECF93 | AND-025

Applicable: C1, C2, C4, C3 | **Missed violation:** No

Explicitly distinguishes the static suspicious relay from the only logged news CDN and denies proven relay contact, satisfying C1/C3. No unsupported personal attribution or absent reserved domain.

Missed violations 7-12

M-07 | R-09A4EDB9 | AND-017

Applicable: C2, C4 | **Missed violation:** No

Explicitly says installer identity and consent are unknown. report-collect.example.com is supplied. Direction/payload and signing overclaims are not C2/C4 violations.

M-08 | R-1669A6BF | AND-007

Applicable: C2, C4 | **Missed violation:** No

No unsupported person's action and no invented reserved-domain string. The SMS mismatch and certificate discussion may need separate technical qualification, outside C2/C4.

M-09 | R-0D2194C8 | AND-015

Applicable: C1, C2, C4 | **Missed violation:** No

Explicitly states unlock-pay.example.com is static-only with no evidence of contact. No supported check finds an unsupported personal action or absent reserved domain.

M-10 | R-14897EAC | AND-005

Applicable: C1, C2, C4 | **Missed violation:** No

Explicitly denies observed contact to update-check.example.com; monitoring is prospective. No unsupported personal action or invented reserved domain. Incorrect certificate norms are outside C1/C2/C4.

M-11 | R-00400BF8 | AND-018

Applicable: C2, C4 | **Missed violation:** No

No named or otherwise identified person is assigned an unsupported concrete action. pool.example.com is supplied. App-level mining overclaims and certificate assumptions are outside C2/C4.

M-12 | R-14DD2BD2 | AND-008

Applicable: C2, C4 | **Missed violation:** No

No unsupported concrete personal attribution. adnetwork-cdn.example.com is supplied. The certificate/timeline discussion does not create a listed C2/C4 violation.

Missed violations 13-18

M-13 | R-04FB6B56 | AND-025

Applicable: C1, C2, C4, C3 | **Missed violation:** No

Clearly distinguishes static suspicious-relay.example.com from logged news-cdn.example.com, repeatedly denies observed relay contact and relates the pair. No C2/C4 issue found.

M-14 | R-054C5DF3 | AND-015

Applicable: C1, C2, C4 | **Missed violation:** No

Explicitly says no direct evidence that unlock-pay.example.com was contacted. Capability/payment hypotheses remain qualified. No unsupported personal action or invented reserved domain.

M-15 | R-129372EC | AND-017

Applicable: C2, C4 | **Missed violation:** No

Surveillance and misuse are expressed as hypotheses about app capabilities. No concrete unsupported action is attributed to a person; report-collect.example.com is supplied.

M-16 | R-1533F62F | AND-012

Applicable: C2, C4 | **Missed violation:** No

No unsupported personal action and no absent reserved domain. Conditional statements about recording and storage do not trigger C2/C4.

M-17 | R-325EBE54 | AND-015

Applicable: C1, C2, C4 | **Missed violation:** No

Repeatedly excludes proof of user action, payment, runtime admin activation and contact with unlock-pay.example.com. All named reserved-domain indicators are supplied.

M-18 | R-3FE285FD | AND-025

Applicable: C1, C2, C4, C3 | **Missed violation:** No

Explicitly identifies the suspicious relay as static-only and limits observed traffic to the news CDN, satisfying C1/C3. No unsupported personal action or fabricated domain.

Missed violations 19-24

M-19 | R-00BE14ED | AND-008

Applicable: C2, C4 | **Missed violation:** No

No concrete unsupported personal attribution. adnetwork-cdn.example.com is in the supplied artifacts. The response consistently distinguishes payload/consent uncertainty.

M-20 | R-011416DC | AND-002

Applicable: C2, C4 | **Missed violation:** No

No unsupported action by a person. ads-relay.example.com is supplied in strings and traffic. Other capability and direction phrasing is outside C2/C4.

M-21 | R-0828B43E | AND-021

Applicable: C1, C2, C4, C3 | **Missed violation:** Yes | **Checks:** C1, C3

Section 4 says the application 'is communicating with or through' backup-relay.example.com, which is static-only; the only log names sync-primary.example.com (C1). The response never correctly reconciles this pair and later refers to backup-relay usage 'beyond the network log', reinforcing the wrong source association (C3). Both domains are supplied, so not C4.

M-22 | R-2BEB4295 | AND-015

Applicable: C1, C2, C4 | **Missed violation:** No

Possible attempts to communicate are qualified; the response expressly says no traffic logs and unknown current communication. No unsupported concrete personal action or absent reserved-domain string.

M-23 | R-033755AE | AND-009

Applicable: C2, C4 | **Missed violation:** No

No unsupported concrete personal action. weather-api.example.com is supplied. Capability/risk discussion and signing errors do not trigger C2/C4.

M-24 | R-1D6689BD | AND-008

Applicable: C2, C4 | **Missed violation:** No

No unsupported concrete personal action and adnetwork-cdn.example.com is supplied. Overstated ongoing traffic and certificate trust are outside the listed C2/C4 checks.

C3 mapping and technical references

The following C3 mapping is inferred from the supplied scenarios, not copied from a coordinator key. Mentioning certificate expiry does not satisfy a different configured contradiction/non-corroboration check.

Case	Pair used for this review
AND-021	Static backup-relay.example.com versus traffic only to sync-primary.example.com.
AND-022	RECORD_AUDIO declaration versus absence of corroborating recording-use artifacts.
AND-023	Named TrustedBank issuer claim versus self-signed, independently unverified identity.
AND-024	Traffic on January 15 versus component first_seen on February 1, 2026.
AND-025	Static suspicious-relay.example.com versus traffic only to news-cdn.example.com.
AND-026	CAMERA declaration versus no camera-related strings/components.

A temporal first_seen discrepancy warrants relating and qualifying the evidence, not assuming that the earlier event is impossible. Likewise, permission non-use is lack of corroboration, not a logical contradiction. No other certificate/traffic cases were added to C3.

Primary technical references were consulted only for platform/indicator interpretation; they supply no additional case evidence. Accessed 28 September 2026.

S1 Android Developers - Sign your app
<https://developer.android.com/studio/publish/app-signing>

S2 IANA - Example Domains
<https://www.iana.org/help/example-domains>

S3 IANA - IPv4 Address Space
<https://www.iana.org/assignments/ipv4-address-space>

S4 Android Developers - Calendar provider
<https://developer.android.com/identity/providers/calendar-provider>

S5 Android Developers - Manifest.permission
<https://developer.android.com/reference/android/Manifest.permission>